CONFIDENTIAL · 409A EVIDENCE

EchoAurion

409A Compliance & Intellectual-Property Evidence Pack

PREPARED	**May 12, 2026**
PLATFORM	**EchoAurion / LUCCCA**
AUTHOR	**William Sears · Founder**
DISTRIBUTION	**Counsel · Appraiser · Investor**

Doctrine: even on a hit, the walkback continues — which trial was tightest, and what did it know?

Quick Links

Tap any chapter to jump there directly. These same links are also restated in the Index at the back of the document.

Table of Contents

Executive Summary

Purpose of this Document

This evidence pack consolidates the **409A valuation readiness scorecard** and the **complete intellectual-property positioning portfolio** for the EchoAurion / LUCCCA platform into a single, signable, audit-ready PDF.

It is intended to be handed to:

1. **Independent appraisers** performing a §409A valuation of common stock.
2. **Patent counsel** preparing provisional / non-provisional filings.
3. **Investors / acquirers** during due diligence.
4. **Internal stakeholders** as a checkpoint of compliance posture.

What's Inside

- **§409A Scorecard** — 67-item readiness matrix across deployment integrity, codebase quantification, intangible-asset separability, IP, data assets, reproducibility, governance, risk, and supporting valuation evidence.
- **Architecture Connections** — current state of the EchoAurion subsystems and the integrations that already produce defensible data flows.
- **Patent Portfolio** — positioning strategy plus a fully drafted *doctrine-enforcement* patent application.
- **P-series Legal Packets** — IP assignment, filing/vendor, privacy, and cap-table guides.
- **T-series Supplementals** — Terms of Service, SLA, accessibility / cookies.

How to Read

The Table of Contents on the following page is **clickable** in any modern PDF reader — every chapter, sub-chapter, and Quick-Link bookmark navigates directly to that section. The Index at the back is the same set of Quick-Links restated for printed reference.

> *Doctrine note: even on a hit, the walkback continues — which trial was tightest, and what did it know? The pursuit is the discipline.*

409A Compliance Scorecard

409A Valuation Readiness Scorecard

EchoAurum / LUCCCA · Generated 2026-05-12

> *Scoring rubric: 🟩 READY (artifact exists, dated, defensible) · 🟨 PARTIAL (in flight, needs collation) · 🟥 NOT STARTED (must build before appraiser engagement) · ⚪ N/A*

Section 1 · Deployment Integrity (BLOCKER — fix first)

#	Item	Status	Evidence / Action
1.1	Production build verified (no Vite dev signatures)	🟨	`pnpm run build:client` produces `dist/spa/` — confirm `curl -I https://cfo-toolkit-deploy.preview.emergentagent.com/` shows static asset headers. Pin a build for valuation.
1.2	Build artifact hash recorded matching git commit	🟥	Need: capture `git rev-parse HEAD` + checksum `dist/spa/assets/*.js` at appraisal commit. Script-able in 1 line.
1.3	Source maps stripped or access-controlled	🟨	Vite default emits `.map` files — set `build.sourcemap: false` in `vite.config.ts` for the valuation build OR move maps behind auth.
1.4	Screenshot/log evidence of broken→fixed state dated	🟨	We have `/app/test_reports/screenshots/*.png` from iter266 audit fixes. Annotate + bundle.

Highest-leverage fix: Add a `scripts/freeze-build.sh` that does `git rev-parse HEAD > BUILD_HASH && sha256sum dist/spa/assets/*.js > BUILD_CHECKSUMS && zip -r dist-frozen.zip dist/`. ~10 lines.

Section 2 · Codebase Quantification (COCOMO II Inputs)

#	Item	Status	Evidence / Action
2.1	Total LOC by language	🟨	`cloc /app/client /app/backend --exclude-dir=node_modules,dist` will produce the table. Tracked: TS/TSX, Python, CSS, MD.

#	Item	Status	Evidence / Action
2.2	LOC per named algorithm	🟥	Need: per-module audit. Files of reference: `echo_schedule.py` (Labor Brain), `chef_outlet.py` (Monte Carlo + Auto-Build), `beverage_network.py` (Network + VIP Pre-Check), `vip_tracker_iter241.py` (VIP Atlas).
2.3	Cyclomatic + cognitive complexity per module	🟥	`radon cc -a /app/backend` for Python · `eslint --plugin sonarjs` or `cyclomatic-complexity` for TS.
2.4	Duplication ratio	🟥	`jscpd /app/client /app/backend --min-lines 8` produces JSON report.
2.5	Test coverage per module	🟨	`/app/test_reports/iteration_*.json` shows backend coverage by endpoint suite. Frontend: NOT YET — add Vitest run with `--coverage`.
2.6	Dependency count + proprietary vs OSS (SBOM)	🟥	`cyclonedx-npm` + `cyclonedx-py` produce CycloneDX SBOMs.

Highest-leverage fix: Single Makefile target `make valuation-evidence` that runs cloc + radon + jscpd + cyclonedx and dumps everything under `/app/valuation/evidence/$(date +%F)/`.

Section 3 · Intangible Asset Separability (CORE 409A EVIDENCE)

Four named algorithms — each needs the same evidence pack:

3a · Decision Clearance (= Labor Brain Advisory Rail)

#	Item	Status
3a.1	Module boundary (files + entry points)	🟩 `backend/routes/echo_schedule.py:1-573` (dashboard aggregator) + `:575-810` (labor-brain rules engine, 5 prioritized rec types, severity weighting); frontend `client/modules/Schedule/index.tsx` `LaborBrainRail` component
3a.2	Call graph as distinct subsystem	🟥 produce `pyan3` or `pydeps` diagram
3a.3	Functional spec in operator language	🟩 `/app/memory/PRD.md` iter266.11 section
3a.4	Novelty / non-obviousness	🟥 write claim: "Rule-based prioritization of labor-coverage anomalies surfaced as 1-tap auditable PAFs against live KPI tiles — distinct from threshold-only alerting (7shifts) and from generic anomaly detection (Toast)"
3a.5	Git timeline	🟨 `git log -- backend/routes/echo_schedule.py`

#	Item	Status
3a.6	Sole/primary author attribution	🟨 `git shortlog -sn -- backend/routes/echo_schedule.py`

3b · Operational Collision Detection (= cross_dept_borrow + Schedule rules + BEO shared-prep)

#	Item	Status
3b.1	Module boundary	🟩 `backend/routes/cross_dept_borrow.py` , `backend/routes/echo_schedule.py` shift_conflict logic, BEO same-day-prep aggregator in `chef_outlet.py:_event_detail`
3b.2	Call graph	🟥
3b.3	Spec in operator language	🟨 PRD has fragments; consolidate into a single 1-pager
3b.4	Novelty	🟥 write claim: "Cross-departmental borrow detection that respects POS revenue scoping + scheduled position skills + sister-outlet coverage gaps — vs. simple shift-trade UIs in 7shifts/ Homebase"
3b.5	Git timeline	🟨
3b.6	Author attribution	🟨

3c · Yield-Aware Costing (= Chef Outlet Dashboard MC forecast + invoice→recipe pipeline + commissary COGS + VIP Beverage Pre-Check)

#	Item	Status
3c.1	Module boundary	🟩 `backend/routes/chef_outlet.py` (Monte Carlo bootstrap @ 1k/2k/5k/7500 iters with normal-noise overlay over outlet_capture_daily history; YTD aggregator); `backend/routes/beverage_network.py` (VIP Pre-Check expected-need heuristic; central + outlet velocity aggregator); commissary/* routes for COGS
3c.2	Call graph	🟥
3c.3	Spec in operator language	🟩 PRD iter266.12, 266.14, 266.17

#	Item	Status
3c.4	Novelty	🟥 write claim: "Yield-aware forecasting that bridges Monte Carlo revenue prediction with central-purchasing on-hand vs. per-outlet velocity — vs. siloed forecasting (MarketMan inventory only) and siloed POS forecasting (Toast)"
3c.5	Git timeline	🟨
3c.6	Author attribution	🟨

3d · Echo AI^3 / Guardian / Prophet (= the orchestration layer)

#	Item	Status
3d.1	Module boundary	🟨 Echo AI^3 surfaces are in `client/components/echo/*`, `client/modules/*` (every dashboard); Guardian = audit-trail writes in routes; Prophet = the Monte Carlo. Need a single map.
3d.2	Call graph	🟥
3d.3	Spec in operator language	🟥 most critical — Echo AI^3 is the unique value prop. Write a 2-pager.
3d.4	Novelty	🟥 write claim: "Pattern-recognition + recommendation orchestration across hospitality verticals (labor + costing + inventory + VIP + BEO) with persistent audit trail (Guardian) and forecast self-calibration (Prophet's feedback loop) — no competitor pairs all five"
3d.5	Git timeline	🟨
3d.6	Author attribution	🟨

Highest-leverage fix: A single `valuation/algorithms/{a,b,c,d}.md` 2-pager per algo with sections: Files · Inputs · Outputs · Heuristic Logic · Novelty Statement · Competitor Delta. ~4-6 hours of writing.

Section 4 · Development Effort Evidence

#	Item	Status	Evidence / Action
4.1	Git history export (~5y window)	🟨 `git log --since="5 years ago" --pretty=format:'%H,%ai,%an,%ae,%s' > valuation/git-history.csv`	
4.2	Commit cadence + authorship	🟥 `pip install git-of-theseus && git-of-theseus-analyze` produces line-survival graphs by author	
4.3	Major architectural milestones	🟨 PRD has fragments; build a single timeline doc: LUCCCA → panel arch → Echo AI³ → Buffet Builder → Monte Carlo → BEO Command Center	
4.4	Contractor invoices / 1099s	⚪ N/A if sole-author; document explicitly	
4.5	Founder time-allocation narrative	🟥 "35 yrs hospitality × 5 yrs dev = labor input multiplier" — 1-page narrative	

Section 5 · Market + Competitive Evidence

#	Item	Status
5.1	Named competitor list w/ positioning	🟨 Toast / 7shifts / MarketMan / Tripleseat — write a 2x2 grid w/ feature matrix
5.2	Outreach log for 7 integration partners	🟥
5.3	LOIs / pilots / NDAs	🟥
5.4	Customer pipeline	🟥
5.5	TAM/SAM/SOM w/ sources	🟥

Section 6 · IP + Legal Hygiene

#	Item	Status
6.1	Trademark status for the 6 names	🟥 USPTO search + intent-to-use filings
6.2	Domain ownership documentation	🟨
6.3	Founder IP assignment agreement	🟥 boilerplate; critical
6.4	Cap table	🟨
6.5	Entity formation docs	🟨
6.6	OSS license compliance review	🟥 `cyclonedx + license-checker` — verify no AGPL/GPL contamination

---

Section 7 · Financial Baseline

#	Item	Status
7.1	Bank statements covering dev period	⚪ founder-side artifact
7.2	Revenue (consulting/pilots)	⚪
7.3	Burn rate + runway	⚪
7.4	Prior valuations (SAFEs/notes)	⚪

Section 8 · Forward-Looking Documentation

#	Item	Status
8.1	Product roadmap w/ dated milestones	🟩 `/app/memory/PRD.md` has rolling iter266 changelog
8.2	Buffet Builder build brief	🟨 exists separately; link from valuation index
8.3	Website audit + remediation plan	🟥
8.4	Network intelligence / Bloomberg-Terminal thesis	🟥 highest-strategic-value missing doc

---

Section 9 · Audit-Defensibility Artifacts

#	Item	Status
9.1	Every tool output exported as signed/dated PDF or JSON	🟥 `/app/test_reports/iteration_*.json` exists for backend but not signed
9.2	Single index doc mapping evidence→claim	🟥 THIS DOC + a cross-reference matrix
9.3	Methodology notes for self-computed metrics	🟥 COCOMO II assumptions doc
9.4	Chain-of-custody log	🟥 who/when/from-which-commit per artifact

---

Section 10 · Appraiser Engagement Readiness

#	Item	Status
10.1	Shortlist of ASA/ABV/CVA credentialed appraisers	🟥
10.2	Budget range confirmed ($5-8K mid-tier)	⚪ founder decision
10.3	Target turnaround window aligned w/ option grants	⚪
10.4	NDA template	🟥
10.5	Single POC + clean data room	🟥 Google Drive or Dropbox folder mirroring this scorecard structure

---

Roll-up Summary

Section	Total Items	🟩 Ready	🟨 Partial	🟥 Not Started	⚪ N/A
1 · Deployment Integrity	4	0	3	1	0
2 · Codebase Quantification	6	0	2	4	0
3 · Intangible Asset Separability	24	4	10	10	0
4 · Development Effort	5	0	2	2	1
5 · Market + Competitive	5	0	1	4	0

Section	Total Items	🟩 Ready	🟨 Partial	🟥 Not Started	⚪ N/A
6 · IP + Legal Hygiene	6	0	2	4	0
7 · Financial Baseline	4	0	0	0	4
8 · Forward-Looking	4	1	1	2	0
9 · Audit-Defensibility	4	0	0	4	0
10 · Appraiser Readiness	5	0	0	3	2
TOTAL	**67**	**5 (7%)**	**21 (31%)**	**34 (51%)**	**7 (10%)**

Highest-leverage Next Moves (if time-constrained)

1. **Section 3 algorithm 2-pagers** (4-6h writing) — turns the code from "a blob" into "4 distinct intangibles," materially affecting valuation.
2. `make valuation-evidence` **Makefile** (1h) — auto-runs cloc/radon/jscpd/cyclonedx/git-of-theseus and dumps under `valuation/evidence/$(date)/`.
3. `scripts/freeze-build.sh` (10min) — records commit hash + asset checksums so appraiser knows exactly what they're valuing.
4. **Section 9 chain-of-custody** (1h) — wraps everything else; mandatory for IRS defense.
5. **Section 6.3 IP assignment** (founder + counsel ~$500-2K) — without this, the algorithms arguably belong to the founder personally, not the entity, and the 409A is meaningless.

What I cannot help with from inside the codebase

- Trademark filings (USPTO)
- IP assignment agreement (counsel)
- Cap table / entity docs (founder-side)
- Bank statements / financials (founder-side)
- Appraiser shortlist + engagement (founder-side)

What I can generate next-round in code

- `make valuation-evidence` Makefile + all the tool outputs it produces
- The 4 algorithm 2-pagers (3a-3d Section 3 deliverables)
- `scripts/freeze-build.sh`

- A chain-of-custody log generator that reads git + signs each artifact
- The Bloomberg-Terminal-for-hospitality thesis doc (Section 8.4)
- The competitor 2x2 matrix (Section 5.1)

Just say the word.

Architecture Connections — Free Wins Roadmap

EchoAurion · Architecture Connections — "Free Wins" Roadmap

Generated: iter267 · 2026-02 · William Sears Studio
Purpose: Show every existing backend that the UI can lean on *today* without writing new business logic. Each row is something you can wire up in <1 day because the data already exists.

TL;DR

The Chronos → MaestroBQT → EchoEvents Studio → Beverage Network → VIP Atlas chain is already a closed loop on the backend. Most of the "next features" the user keeps asking for are just **UI joins of payloads we already produce**. The cheapest wins are joining those payloads together inside one panel.

```
                          ┌────────────────────────────────────┐
                          │  Chronos · roll-up shell  │
                          │   (district → outlet)     │
                          └─────────┬──────────────────────────┘
                               │ openPanel(chef-outlet-dashboard, outlet_id)
                               ▼
  ┌──────────────────────────────────┐
┌────────────────────────────────────┐
┌────────────────────────────────────┐
  │ Beverage Network      │◄───►│  Chef Outlet Dashboard   │◄───►│ MaestroBQT BEO Timeline  │
  │ /vip-precheck         │     │ /chef-outlet/*          │     │  /chef-outlet/beo-time…  │
  │ /briefing, /transfer  │     │ YTD · MC forecast       │     │ detail · auto-build     │
  └────────────┬────────────────┘
└──────────────┬─────────────────────┘
└──────────────────┬─────────────────┘
          │                      │                        │
          ▼                      ▼                        ▼
  ┌──────────────────────────────────┐
┌────────────────────────────────────┐
┌────────────────────────────────────┐
  │ VIP Atlas + Concierge │     │ Echo AI³ Auto-Build      │     │ Echo Events Studio       │
  │ /vip-tracker/list     │     │ (recipes · prep · POs)   │     │ /demo-create · feed      │
  └──────────────────────────────────┘
└────────────────────────────────────┘
└────────────────────────────────────┘
```

---

1. Already-Wired Backends (you don't need to build these)

Backend route	Data it produces	Where it's already consumed	Where you could ALSO use it (free win)
`/api/chef-outlet/dashboard`	YTD sales + Monte Carlo 1-7d forecast	Chef Outlet Dashboard panel	**Chronos district roll-up** (sum per outlet)
`/api/chef-outlet/beo-timeline/{id}/detail`	Menu + prep + setup + schedule team	BEO Timeline drawer	**MyEcho mobile** banquet shift view
`/api/chef-outlet/beo-timeline/.../auto-build`	recipes + prep rows from menu	"Auto-Build (Echo AI³)" button	**Pre-week production plan** in MaestroBQT
`/api/beverage-network/briefing`	Cross-outlet inventory rollup	Beverage Director panel	**Concierge VIP Precheck** (already!)
`/api/beverage-network/vip-precheck`	Shortfall units, days supply	Concierge VIP Atlas tile	**GM Daily Briefing email** (already!)
`/api/beverage-network/transfer-link`	1-click intra-outlet transfer landing	GM Daily Briefing email	**Echo Activity tape** auto-row when a transfer fires
`/api/echo-events-studio/activity-feed`	Real Echo AI³ pipeline steps	Echo Command Bar EventTape	**Owner dashboard** "what is Echo doing right now" tile
`/api/echo-events-studio/demo-create`	7-step BEO auto-build (PO + layout + recipes)	Run-Demo button	**Onboarding tour** — show day-1 user a complete pipeline
`/api/supplier-catalog/compare`	Sysco vs USF price diff for any item	Supplier Catalog Compare tab	**Auto-PO** chooses cheapest by default
`/api/supplier-catalog/price-history/{sku}`	26-week price walk (iter267 NEW)	Supplier Deep Dive modal	**Forecast Hub** food-cost CPI line
`/api/supplier-catalog/outlet-usage/{sku}`	Units/week per outlet (iter267 NEW)	Supplier Deep Dive modal	**Plate Costing** "are we paying the right price" check
`/api/help-agent/ask` (now LLM-backed)	Free-form Q&A (calculus → P&L)	Echo Command Bar drawer (iter267)	**In-line panel coach** — any panel can call ask()
`/api/admin/users/{id}/onboarding-bundle`	Role's default panel + sidebar pins	First-login bootstrap (NEW iter267)	**Sidebar.tsx** can pre-pin items from this endpoint
`/api/admin/role-provisioning`	Full role→bundle map	Admin "preview role" tooltip	**CSV bulk user import** assigns by role automatically

Backend route	Data it produces	Where it's already consumed	Where you could ALSO use it (free win)
`/api/ai3-nlp/transcribe`	Whisper voice → text	Echo Command Bar mic (NEW iter267)	**Hands-free Recipe capture**, **BEO voice notes**

---

2. Connections the UI Should Make Next (cheapest first)

2.1. Chronos roll-up chain (P2 in backlog · ~½ day)

- **What:** Director / district view sums `/api/chef-outlet/dashboard` across owned outlets.
- **Build:** Add `/api/chronos/roll-up?scope=district&id=...` that loops outlets and aggregates `ytd_sales`, `mc_p50`, `mc_p90`. The per-outlet endpoint already does the heavy math.
- **Free win:** No new analytics. Just a fan-out + sum.

2.2. Owner dashboard "Echo Live" tile (~2 hours)

- **What:** Drop the `EchoCommandBar` `EventTape` content into a tile on the GM/Owner dashboard so they don't have to open the drawer.
- **Build:** Reuse `useEffect(load /api/echo-events-studio/activity-feed)` from `EchoCommandBar.tsx` — render the last 5 rows in a card. No new endpoint.
- **Free win:** Sells the "we have an AI doing real work" story without any backend lift.

2.3. BEO Drawer ⇒ Supplier Deep Dive (~2 hours)

- **What:** Inside the BEO Production Sheet, every ingredient row gets a "View pricing" link → opens the new Supplier Deep Dive modal pre-keyed to that SKU.
- **Build:** Hash the BEO recipe ingredient → catalog SKU by `name` match; if hit, render `<a onClick={() => openSupplierDeepDive(sku)}>`. Re-uses the modal already built in iter267.
- **Free win:** Chef Gio can confirm a vendor + lock pricing without leaving the BEO.

2.4. VIP Atlas → BEO auto-mark "VIP arrival in flight" (~2 hours)

- **What:** When `vip_beverage_alerts` has `status=open` for a VIP whose `event_id` matches a BEO, the BEO card in the MaestroBQT timeline gets a 🟡 VIP-on-floor badge.
- **Build:** On the BEO Timeline payload, left-join `vip_beverage_alerts` by `event_id`. No new endpoint.
- **Free win:** Concierge + Banquet finally talk through the system instead of Slack.

2.5. Echo Activity tape → Audit & Security panel (~1 hour)

- **What:** Mirror the merged `EventTape` into the `audit-security` panel so the compliance officer has the exact same feed.
- **Build:** Audit panel re-fetches `/api/echo-events-studio/activity-feed?limit=200`. Done.

2.6. Onboarding bundle → Sidebar.tsx (~3 hours)

- **What:** When a user hits the shell, GET `/api/admin/users/{me}/onboarding-bundle` and use `sidebar_pins` + `default_panel` to:
- pre-pin those items at the top of the sidebar, and
- if it's their first session (`last_login==null`), auto-open `default_panel`.
- **Build:** One `useEffect` in `Sidebar.tsx`. The endpoint already exists (iter267).
- **Free win:** Closes the "Onboarding Auto-setup" P1 item from William's notes.

2.7. GM Briefing PDF (~2 hours)

- **What:** `/api/beverage-network/vip-precheck/gm-daily-briefing` already returns server-rendered HTML. Pipe through WeasyPrint to expose `gm-daily-briefing.pdf` for archival.
- **Build:** Add `?format=pdf` branch. Use the same WeasyPrint pipeline as the 409A doc.

2.8. Help Agent → in-panel Coach button (~2 hours)

- **What:** Every panel gets a "?" pill bottom-right. Click → opens Echo drawer with a pre-filled context-aware question (e.g. "How do I read this panel?").
- **Build:** `useContext(PanelId)` → `POST /api/help-agent/ask {context_panel: pid}`. The endpoint already accepts `context_panel`.

---

3. Joins that Convert Three Backends into One Product Story

These are mini-products that emerge for free once you join the existing payloads:

A. "Pre-Week Production Plan" = MaestroBQT week × Echo Auto-Build × Supplier Catalog

1. `MaestroBQT /week?starts=…` → all BEOs this coming week.
2. For each BEO → `auto-build` already returns prep rows.
3. Aggregate prep across the week → list of ingredients with totals.
4. Hit `/api/supplier-catalog/compare` once per ingredient → cheapest vendor list.
5. Drop into `/api/supplier-catalog/auto-po` → single weekly PO.

> *Effort: 1 day. Backend already produces every input.*

B. "VIP Service Brief" = VIP Atlas × Beverage Network × Echo Concierge

1. `/vip-tracker/list?status=upcoming&days=7` → who's arriving.
2. Per VIP → `/vip-precheck` for shortfalls and `/transfer-link` for fixes.
3. Per VIP → `/concierge/notes/{guest_id}` (already exists) for likes/dislikes.
4. Render as a 1-page "morning huddle" PDF.

> *Effort: ½ day. PDF pipeline is the only new piece.*

C. "Chronos Live" = Chef Dashboard × Echo Activity × Beverage Network

1. Top strip: per-outlet YTD + MC forecast (already).
2. Middle band: live Echo Activity tape filtered to this outlet (already).
3. Bottom row: beverage shortfalls + open transfers (already).

> *Effort: 4 hours of UI composition. Zero new backend.*

D. "Owner Tape" = Echo Activity × Aurum P&L × VIP Atlas

1. Daily digest email: top 10 Echo actions, P&L delta vs forecast, VIP highlight.
2. Same WeasyPrint pipeline as 409A doc.

> *Effort: 1 day. Aurum P&L endpoints exist, VIP exists, Activity exists.*

---

4. What the Sidebar Knows But Doesn't Yet Use

Today: `Sidebar.tsx` renders a fixed list per RBAC. From iter267 we now have `/api/admin/role-provisioning` returning a richer map (modules + default_panel + sidebar_pins).

Free win: Make Sidebar.tsx *data-driven* from `/api/admin/users/{me}/onboarding-bundle`. Removes the hard-coded role gates inside the sidebar and centralizes them in one provisioning map. Net: fewer code changes when adding a role.

5. Hot-Path Performance Notes (don't skip)

- **Calendar BEO merge** still slices after combining (handoff note). Once volume crosses ~800 BEOs/month, this drops events. Move to a true paginated merge endpoint `/api/calendar/events?cursor=...`. Same payload, no UI changes.
- **Activity feed** is polled every 8s in the drawer. If multiple drawers open across the shell, push it to a context provider + single interval.
- **Supplier Catalog Deep Dive** does two parallel fetches per click. If users click rapidly, debounce 200ms or cache by sku.

6. Recommended Order (1-week sprint)

Day	Ship	Why
Mon	2.6 Sidebar.tsx data-driven from bundle	Visible to every user instantly
Tue	2.2 Owner "Echo Live" tile + 2.5 Audit feed	Two free wins from one endpoint
Wed	2.3 BEO Drawer → Supplier Deep Dive	Chef-facing, ROI in one shift
Thu	2.4 VIP-on-floor badge in BEO Timeline	Bridges Concierge + Banquet
Fri	A. Pre-Week Production Plan (mini-product)	Demonstrable "Echo ran our week" moment

After this week the only remaining backend new-builds are: 1. `/api/chronos/roll-up` (district fan-out) 2. WeasyPrint PDF endpoints (`gm-daily-briefing.pdf`, `owner-tape.pdf`) 3. Calendar paginated merge

Everything else is composition.

7. Risks / Watch-outs

- **Single source of truth for SKU → ingredient name.** Supplier Deep Dive joins by name today. If chef recipes spell items differently than catalog, joins miss. Either canonicalize or add a `recipe_sku_alias` map.
- **Talk-to-talk** uses Whisper via `/api/ai3-nlp/transcribe` — costs $0.006 / min. Cap to 30s/clip in the UI.
- **LLM Q&A** (`/api/help-agent/ask`) is now LLM-backed. Add rate-limiting once you take this public.
- **Role provisioning** does not retroactively patch existing accounts. Run `apply-role-defaults` once after deploy to backfill.

Patent Positioning Strategy

Patent Positioning Strategy — How to Frame the Doctrine Invention

> *Companion to* `PATENT_DRAFT_doctrine_enforcement.md`.
>
> *The formal draft is the what. This document is the why and how: the strategic angle, the examiner's narrative, the novelty hooks, the prior-art differentiation, and the pitfalls that kill patents like this if not handled deliberately.*
>
> ***Use this when briefing a patent attorney.*** *It explains the business strategy behind the technical disclosure so they can prosecute claims that protect what actually matters.*

---

§1 — The framing problem (and the trap to avoid)

The instinct is to say *"we have a patent on the doctrine."* That framing is **fatal**. It triggers two immediate rejections:

- **Subject-matter eligibility (35 U.S.C. § 101):** abstract principles, business rules, and ethical frameworks are not patent-eligible after *Alice Corp. v. CLS Bank* (2014). An examiner reading "we patented ethics" stops reading at page one.
- **Prior art:** ethical principles in service industries go back centuries. Hospitality has had codes of guest treatment since Caesar Ritz. You cannot claim novelty on the *idea* of treating guests well.

The correct framing is the inverse. What we patent is the **technical apparatus that makes a behavioral doctrine machine-enforceable** in a class of software systems where, until now, doctrine has been enforced only by humans, audit logs, and hope.

The shift in framing is: from *"we have rules"* to *"we have a machine that prevents rule violations at the moment of attempted commit and produces cryptographic proof of compliance."* The **rules** are not novel. The **machine** is.

This is the same shift Stripe made when patenting payments infrastructure (*Stripe doesn't patent the idea of charging credit cards; they patent the technical apparatus that does it differently*) and the same shift Snowflake made (*not "the idea of a database in the cloud" but a specific architecture for separating storage from compute*).

Tell the attorney: *"We are not patenting ethics. We are patenting the runtime gate that enforces ethics as a precondition for state transition."*

§2 — Post-Alice eligibility: the two-step survival strategy

The *Alice* test asks two questions:

1. **Is the claim directed to an abstract idea?** For a doctrine-enforcement claim, the answer is *partially yes* — there is an abstract idea component (ethical rules). Don't fight this. Concede it and move to step 2.
2. **Does the claim contain an "inventive concept" sufficient to transform the abstract idea into a patent-eligible application?** This is where we win or lose. Our inventive concept is **the specific technical apparatus**: the pre-commit gate as a system component, the cryptographic linkage between event records and versioned doctrine, the static-analysis import-graph partition, the replay engine, the correlation engine.

The claims must be drafted to **emphasize the technical apparatus**, not the rules being enforced. Compare:

- **Bad framing (loses on Alice step 1):** *"A method comprising: receiving guest data; checking if the guest data violates a privacy rule; rejecting the data if so."* This is just policy-checking. Pure abstract idea. Dead.
- **Good framing (survives Alice via inventive concept):** *"A computer-implemented method comprising: storing a cryptographically-signed versioned doctrine in a doctrine registry; intercepting, at a doctrine gate disposed between a service layer and a persistence layer, every state-changing operation; evaluating the operation against executable predicates of the current doctrine version; conditionally persisting the operation to an append-only event log along with a cryptographic hash of the doctrine version under which it was validated; ..."*

The good framing wins because: - It specifies a **concrete arrangement of system components** (registry, gate, log, hash) that is not abstract. - It produces a **technical artifact** (the cryptographic linkage) that does not exist in conventional systems. - It improves the **functioning of the computer system itself** (a recognized *Alice* safe harbor) by enabling cryptographic proof of compliance state.

The attorney's job is to ensure every claim is drafted in the *good framing* style: concrete components, technical artifacts, computer-system improvements.

§3 — The narrative arc: the story the examiner needs to hear

A patent application is, fundamentally, a *story* told to an examiner. The story has a beat structure that, when followed, maximizes the chance of allowance. Here is the beat structure for this invention:

Beat 1 — The technical problem is real and recognized

Open with a problem the examiner already accepts as legitimate: **privacy-policy-to-code drift in AI service platforms.** Every major platform (Google, Meta, OpenAI, Salesforce) has been publicly caught violating its own privacy policy because the policy and the code drifted. This is documented in regulatory enforcement actions, journalism, and academic literature. It is not contested.

Establishing this beat does two things: - Pre-empts "this is just business" rejections (it's a technical problem with technical consequences); - Anchors the invention in a problem space the examiner is already inclined to view as legitimate technical territory.

Beat 2 — Conventional solutions fail, and the failures are technical

List the conventional approaches (code review, audit logs, RBAC, DLP, policy-as-code for infrastructure) and explain *technically* why each fails for doctrine enforcement:

- Code review: human, fallible, distributed-failure-mode invisible
- Audit logs: detective not preventive; retroactive remediation is incomplete
- RBAC: controls *who* accesses *what data*, not *what operations* are performed on data; legitimate-access misuse passes RBAC
- DLP: pattern-matches content; cannot evaluate operations against a versioned principles framework
- Infrastructure policy-as-code (OPA, Sentinel): operates on cloud configuration, not on application data writes

This beat does the prior-art differentiation work *narratively* before the formal prior-art section, priming the examiner to view this invention as filling a real gap.

Beat 3 — The inventive leap

State, in plain language, what is novel: *a versioned executable doctrine evaluated by a pre-commit gate that produces cryptographically-linked event records, with retrospective replay capability under alternate doctrines.*

The phrase **"versioned executable doctrine"** is the inventive-leap phrase. It captures three things in three words: - **versioned** — the doctrine is itself a deployable artifact, not prose; - **executable** — the predicates run, return verdicts, are not interpretive; - **doctrine** — the rules being enforced are explicitly ethical / behavioral (not data-validation rules, not infrastructure policy rules).

Beat 4 — The technical apparatus

The detailed description (§ in the formal draft) should be **aggressively concrete**. Examiners reject claims that read as *"a system to do X"* without specifying *how*. Specify: - the components (registry, gate, log, replay engine, correlation engine, decay module, partition analyzer); - the data structures (the event record schema, the tenet schema, the rejection record schema); - the algorithms (the predicate evaluation order, the cryptographic hashing scheme, the decay tombstoning algorithm); - the interfaces (which component calls which, with what payload).

Concreteness is armor against rejection. Vague claims die. Concrete claims survive even when narrowed.

Beat 5 — The result

End with the *technical effect* — what the system achieves that prior systems could not: - Cryptographically-verifiable doctrine compliance for every historical operation; - Counterfactual analysis under alternate doctrines; - Prevention (not detection) of doctrine violations; - Detection of aggregation drift invisible to per-operation review; - Compile-time impossibility of certain prohibited code paths.

These are **technical effects**, not business benefits. Frame them as such.

---

§4 — The novelty hooks: what we claim is new

A strong patent has three to five "novelty hooks" — specific technical features that are demonstrably new and difficult to design around. Here are ours, ranked by defensibility:

Hook 1 (strongest) — The cryptographic event-doctrine linkage

Every event record carries a hash of the doctrine version under which it was validated. **This is not done in any prior system the inventor has identified.** Audit log systems record what happened; they do not cryptographically bind the operation to the policy version under which it was approved. This linkage enables: - Forensic reconstruction of historical decisions with cryptographic proof of which policy was in effect; - Detection of policy-version tampering (because the hash chain breaks); - Counterfactual replay (because the historical doctrine version is recoverable).

This hook should appear in **the broadest independent claim**.

Hook 2 (very strong) — The compile-time forbidden-path partition

Using static analysis on the import graph to make it **impossible for prohibited code paths to exist in the deployed binary** is substantially stronger than runtime gating. The closest prior art is dependency-cruiser-style architectural fitness functions, but those are typically used for code-organization concerns (don't import from this package) rather than ethical-doctrine enforcement (don't let advertising code import voice tone scores).

This hook should appear as **a dependent claim**, with the parent claim covering runtime gating, so the examiner can fall back to allowing the dependent if the parent is rejected.

Hook 3 (strong) — The cross-correlation aggregation drift detector

Detecting violations that emerge only from the **aggregate** of individually-compliant operations is a genuine novelty. Most compliance systems evaluate each operation in isolation. Cumulative disclosures, role accretion, and temporal drift are blind spots that this engine addresses.

This hook is strong but vulnerable to prior art in the **anomaly detection** literature. The attorney needs to draft this hook narrowly enough to differentiate from generic anomaly detection (*"anomaly detection wrt. a versioned doctrine, not a statistical baseline"*) while broad enough to retain commercial value.

Hook 4 (moderate) — Counterfactual replay under alternate doctrines

Re-running historical events under a candidate alternate doctrine to compute counterfactual outcomes. The closest prior art is in financial-stress-testing (running portfolios under stress scenarios) and software A/B testing (running traffic under alternate code). Neither operates on a versioned ethical doctrine over service operations. This hook is patentable but narrower than hooks 1-3.

Hook 5 (moderate) — LLM-as-extractor with doctrine-gated active learning

Specifically: extractions below a confidence threshold are held pending; corrections pass through the doctrine gate before being incorporated into per-tenant template patches. The combination of (a) confidence-thresholded LLM extraction, (b) human correction loop, and (c) doctrine-gated learning is novel. Each component individually is prior art; the combination is not.

This hook is best filed as a **separate continuation patent** to preserve the broader doctrine-gate patent's claim space.

---

§5 — Prior-art landscape and how we differentiate

The attorney will conduct a formal prior-art search. Below is the inventor's assessment of the landscape so the attorney has a starting map:

Adjacent technologies and how to differentiate

Prior art / adjacent tech	What it does	How we differ
Git pre-commit hooks (Husky, etc.)	Validate code style, run tests before commit	Validate **data writes** at runtime, not code at build time; doctrine is data-content-aware
Database CHECK constraints / triggers	Enforce data-validity rules at write time	Enforce **versioned, signed, externally-reviewable doctrine**, not schema validity; replayable under alternate doctrine

Prior art / adjacent tech	What it does	How we differ
RBAC / ABAC (e.g., OPA Rego)	Control who can access what	Controls **what operations**, not access; evaluates payload semantics not just role/resource pairing
Smart contracts (Ethereum, etc.)	Gated state transitions on a blockchain	Operates in **multi-tenant SaaS** for service-industry operations; doctrine is human-authored, not contract-author-authored
DLP (data loss prevention)	Pattern-match content for exfiltration	Evaluates **operations against a doctrine**, not content against patterns; preventive at write time, not network egress
Policy-as-code for infrastructure (OPA, Sentinel, AWS Config)	Validates cloud-infrastructure changes against policy	Validates **application-data writes**, not infra config; doctrine includes ethical/behavioral predicates not safety/cost rules
Privacy-engineering frameworks (Datafold, Privacera)	Tag and inventory PII; enforce retention	Versioned executable doctrine with **counterfactual replay**; cryptographic event-doctrine linkage; static-analysis path partition
Audit log systems (Splunk, Datadog audit)	Record what happened for retroactive review	**Preventive** (rejects at commit time) not detective; embeds doctrine version in every record
Event sourcing (CQRS, Kafka log)	Append-only log of state changes	Adds **doctrine-version cryptographic linkage** + **rejection log** + **counterfactual replay engine**

The honest concession to make

The closest prior art is **Open Policy Agent (OPA) + event sourcing + blockchain smart contracts** taken together. Each individually is prior art; the **combination** for ethical doctrine over service operations is not. The attorney should:

- Cite OPA and acknowledge it (refusing to cite known close art is grounds for unenforceability under inequitable conduct);
- Differentiate on the **doctrine-as-versioned-deployable-artifact
    - cryptographic event-binding + counterfactual replay** triad that no single OPA-using system combines.

---

§6 — Claim strategy: broad → narrow ladder

The standard tactic is to **claim ladder**: file a broadest claim, plus progressively narrower claims, so that if the broadest is rejected the narrower ones can survive.

Layer 1 — The broadest defensible claim (independent)

"A computer-implemented method for compliance enforcement in a multi-tenant service platform, comprising: storing a cryptographically-signed versioned doctrine; intercepting candidate write operations at a gate disposed between service and persistence layers; evaluating each operation against executable predicates of the doctrine; persisting permitted operations to an append-only log with a hash of the doctrine version; persisting rejected operations to a separate rejection log."

Risk: could be challenged on OPA prior art if the term "doctrine" is read as "policy."

Layer 2 — Narrower (independent or dependent)

Add the **service-industry context** ("for a hospitality service platform mediating guest interactions"). Narrows the application domain, dramatically reduces prior-art exposure. Hospitality is a narrow enough field that prior-art density is low.

Layer 3 — Narrower still

Add **specific tenets** (e.g., "wherein the doctrine includes a predicate enforcing automatic time-based decay of psychologically- sensitive data fields"). Each specific tenet narrows the claim and adds defensibility on the prior art for that tenet.

Layer 4 — Defensive depth

Add hooks 2-5 (compile-time partition, correlation engine, counterfactual replay, LLM extraction) as dependent claims. Each is patentable in isolation if the broader claim falls.

The strategic point

You want the broadest claim to win, but you want the narrowest claim to also stand alone. That way, if a competitor designs around your broadest claim, you may still catch them with the narrower one. The dependent claims are not redundant; they are the trenches behind the front line.

---

§7 — Continuation strategy: the next six patents

The formal draft (§0 of `PATENT_DRAFT_doctrine_enforcement.md`) identifies seven distinct inventions in the doctrine framework. The recommended sequence:

1. **Now (provisional):** the doctrine-gate apparatus (this draft).
2. **+6 months:** the append-only event log + replay (continuation).
3. **+9 months:** the cross-correlation drift detector (continuation).

4. **+12 months:** the compile-time forbidden-path partition (separate application — different inventive territory).
5. **+15 months:** the sensitive-flag decay engine (continuation).
6. **+18 months:** the Monte Carlo counterfactual replay (continuation).
7. **+24 months:** the LLM-as-extractor with doctrine-gated active learning (separate application).

Why staggered: each filing extends the priority date for that specific invention; staggering them creates a **patent thicket** (multiple overlapping patents that competitors must navigate around). A thicket is a more durable moat than a single patent.

Cost: rough order-of-magnitude is **$15-25k per patent** through prosecution to allowance ($5-8k for filing, $3-5k for office-action responses, $7-12k for allowance and maintenance). Seven patents → **$100k-175k total over 4 years**. This is the real number to budget for.

---

§8 — Trademark + trade-secret companions (do these too)

Patents protect technical apparatus. Two companion regimes protect the rest of the brand and tech:

Trademark (file separately, ~$350-1500 per mark + attorney)

- **EchoAurion** (the platform name)
- **LUCCCA** (the framework)
- **EchoAurum** (the financial product)
- **EchoConcierge** (the concierge product)
- **EchoStratus** (the cloud product)
- **EchoCronos** (the time/scheduling product)
- **EchoConnect** (the integrations product)
- **EchoAI³** (the doctrine layer)
- The **black hat with gold lettering** logo (design mark)

File USPTO 1(b) "intent-to-use" if not yet in commerce; convert to 1(a) "in-use" upon launch.

Trade secret (no filing, but documentation required)

The items listed in `PATENT_DRAFT_doctrine_enforcement.md` § "Trade-Secret Inventory" are protected by: - NDA with all employees and contractors; - "TRADE SECRET — DO NOT DISTRIBUTE" header on relevant source files; - Need-to-know access controls; - **A formal trade-secret inventory document** (required to bring a misappropriation claim under the Defend Trade Secrets Act, 18 U.S.C. § 1836).

Trade-secret protection lasts **forever** as long as you keep the secret. Patent protection lasts 20 years from filing and requires public disclosure. **For some pieces (correlation heuristics, LLM prompts, decay parameters) trade secret is the better protection.** The patent draft was deliberately written to disclose *architecture* without disclosing *parameters* — keep it that way.

---

§9 — What kills this patent if not handled right

Three failure modes the attorney needs to watch for:

Failure mode 1 — The "abstract idea" rejection

If the claims read as "rules being enforced" rather than "machine that enforces rules," the examiner will reject under § 101 / Alice. **Mitigation:** every claim must lead with a concrete component (gate, registry, log, hash, partition) and explicitly recite the **technical artifact** produced (the cryptographic linkage, the rejection record, the partition graph).

Failure mode 2 — The OPA prior-art rejection

If the examiner finds Open Policy Agent + event sourcing in the prior-art search, they may reject as obvious combination. **Mitigation:** the application must explicitly cite OPA, explicitly cite event sourcing, and explicitly identify the **non-obvious combination triad** (versioned-deployable-doctrine + cryptographic- event-doctrine-binding + counterfactual-replay) that is the inventive concept.

Failure mode 3 — Public disclosure before filing

The United States has a one-year grace period for inventor disclosure, but **most foreign jurisdictions do not**. If you have publicly disclosed the architecture (blog post, conference talk, public GitHub commit, marketing website) in any of the following, you may have lost foreign rights:

- Any document in this repository visible to non-employees;
- Any commit message describing the architecture;
- Any pitch deck shown to investors without NDA;
- Any conference talk;
- The CLAUDE.md file (if the repo is public).

Action item before filing: - Audit what has been publicly disclosed and when; - Lock down the repository if it is public; - File a provisional **immediately** to establish priority before further disclosure; - For PCT (international), file within 12 months of any prior US disclosure, and ideally within 12 months of the US priority date.

---

§10 — The bottom line for the attorney brief

When you talk to the patent attorney, here is the one-paragraph brief that captures the strategy:

> *"We have built a multi-tenant AI hospitality service platform that enforces a versioned, cryptographically-signed behavioral doctrine through a pre-commit gate disposed between the service and persistence layers. Every state-changing operation is evaluated against the doctrine before persistence; permitted operations are persisted to an append-only event log along with a cryptographic hash of the doctrine version under which they were validated; rejected operations are persisted to a separate rejection log. The architecture supports counterfactual replay under alternate doctrines, cross-correlation drift detection across individually-compliant operations, compile-time static- analysis forbidden-path partitioning of the import graph, automatic time-based decay of sensitive data fields, and an LLM-as-extractor active learning loop in which corrections pass through the doctrine gate before incorporation. We are not patenting the ethical principles being enforced. We are patenting the technical apparatus that makes those principles machine-enforceable in a class of software systems where they have, until now, been enforced only by humans, audit logs, and hope. We anticipate seven distinct continuation filings over the next 24 months covering the related inventions identified in the companion specification. Please advise on prior-art search, claim ladder, and PCT strategy."*

That's the framing. That's how you position it.

---

§11 — Honest closing notes

· This document is **strategy**, not legal advice. Your attorney will refine all of it based on their prior-art search and their read of current examiner behavior at the USPTO art unit your case lands in (likely Art Unit 2447, Computer Networks).

· **The single most valuable thing you can do today** is file a provisional application within 30 days of any further public disclosure. The provisional locks in your priority date and costs ~$300 USPTO fee + $3-5k attorney fee. Do it before any investor pitch, conference talk, or open-sourcing of any related code.

· **The single most expensive thing you can do today** is file the provisional yourself without an attorney. A defective provisional that fails to support later non-provisional claims locks you into a bad priority date you cannot fix. Hire counsel.

· The doctrine-gate apparatus is **genuinely novel** in the inventor's assessment. The attorney's job is to draft claims that capture the novelty in language that survives Alice and differentiates from OPA-style prior art. The claims drafted in `PATENT_DRAFT_doctrine_enforcement.md` are a starting point, not a final form.

· If you only file one patent in your life, file this one. The architecture is the moat. Without it, the doctrine framework is a service offering that competitors can copy in six months. With it, the architecture is yours for 20 years and competitors must either license it from you or design around it (which is expensive and visibly inferior).

Patent Draft — Doctrine Enforcement

Provisional Patent Application — DRAFT

For attorney review. DO NOT FILE WITHOUT COUNSEL.

> ***READ THIS FIRST***
>
> *This document is a **drafting framework** prepared by an AI coding assistant (Claude, Anthropic) at the request of the inventor. It is **not legal advice** and **must be reviewed, edited, and filed by a licensed United States patent attorney or registered patent agent** before submission to the USPTO.*
>
> *Provisional patent applications are non-substantive filings that establish a priority date but expire after 12 months unless converted to a non-provisional. Filing a defective provisional can lock in a bad priority date or fail to support later non-provisional claims. **Use a real attorney.***
>
> *The strategic recommendation in §0 below addresses whether one patent or multiple patents make sense, and whether trade-secret protection should displace patent protection for some pieces of the invention.*

---

§0 — Strategic recommendation (to be discussed with counsel)

The doctrine framework comprises **at least seven distinct technical inventions**, any one of which may warrant its own patent application:

1. **Doctrine-as-Code Enforcement** — pre-commit gate that validates every state transition against an executable behavioral doctrine (the core subject of this draft).
2. **Append-Only Hospitality Event Log with Forensic Replay** — event-sourced architecture with doctrine-compliance metadata on every event.
3. **Cross-Correlation Drift Detector** — surfaces patterns where individually-compliant operations collectively indicate doctrine drift.
4. **Sensitive-Flag Decay Engine** — automatic time-based decay of psychologically-sensitive data classes, enforced at the storage layer.
5. **Compile-Time Forbidden-Path Partition** — static analysis enforcing that certain data classes (e.g., voice tone scores) cannot be imported from certain code paths (e.g., advertising, pricing).

6. **Monte Carlo Counterfactual Doctrine Replay** — engine for retroactively asking "what would have happened under a different doctrine?"
7. **LLM-as-Extractor With Doctrine-Gated Active Learning** — confidence- thresholded LLM extraction with corrections fed back through the doctrine gate before persistence.

Counsel should advise on:

- Whether to file one consolidated application covering the system as a whole (broader claims, weaker per-claim defensibility) or multiple narrower applications (stronger per-patent defensibility, higher cost).
- Which inventions are better protected as **trade secrets** (e.g., the exact correlation heuristics, the LLM prompt scaffolding, the decay rate tuning) rather than disclosed in a patent.
- Whether to file in the **United States only**, or pursue **PCT** for international protection (recommended given hospitality is global).
- Whether **continuations** or **divisionals** should be planned at the outset.

The remainder of this document drafts a single application focused on invention #1 (Doctrine-as-Code Enforcement) with §6 placeholders for the related inventions to be filed separately.

Title of the Invention

System and Method for Code-Enforced Behavioral Doctrine Compliance in Multi-Tenant Service-Industry AI Platforms

(Alternate, narrower titles for counsel to consider:) - *Pre-Commit Doctrine Gate for Append-Only Hospitality Event Logs* - *Apparatus for Enforcing Privacy and Service Tenets as Executable Contracts in AI-Mediated Hospitality Operations*

Cross-Reference to Related Applications

This is a provisional patent application. No related United States or foreign applications have been filed by the inventor on this subject matter as of the filing date. **[Counsel: confirm before filing.]**

Field of the Invention

The invention relates generally to multi-tenant software platforms that mediate human service interactions using artificial intelligence, and more specifically to systems and methods for ensuring that such platforms operate in compliance with declared ethical, privacy, and operational principles. Particular application is to hospitality operations including but not limited to luxury hotels, restaurants, resorts, spas, banquets, and concierge services, in which AI systems process behavioral, biometric, and conversational data of human guests and employees.

Background of the Invention

The problem of doctrine drift in AI service platforms

Modern AI-mediated service platforms collect, analyze, and act upon sensitive human data including but not limited to: voice recordings, emotional valence inferences, behavioral preferences, biometric facial recognition, location traces, purchase histories, and inferred psychological states. Operators of such platforms typically commit, in public-facing privacy policies and terms of service, to specific ethical constraints — for example, that voice analysis will not be used for advertising decisions, that sensitive psychological flags will be deleted after a defined period, or that data will not be shared with third parties.

In conventional implementations, these commitments are enforced **procedurally**, through a combination of:

- Privacy policy documents that bind the operator legally but do not technically prevent violations;
- Code review processes that depend on human reviewers correctly identifying violations;
- Audit logs reviewed retroactively;
- Access-control lists that grant or deny access to data classes by user role.

Each of these conventional mechanisms exhibits known failure modes:

1. **Policy-code drift.** The policy and the code diverge over time as features are added under deadline pressure, leaving the policy accurate as a description of intent but inaccurate as a description of behavior. The operator does not know they are violating their own policy until a regulator or journalist discovers it.
2. **Reviewer fallibility.** Code reviewers may miss subtle violations, particularly when the violation is distributed across multiple commits or services.
3. **Retroactive-only audit.** Audit logs surface violations after they have occurred, after data has been collected, processed, and potentially shared. Retroactive remediation is incomplete.
4. **Permissive defaults.** Access-control systems generally control *who* can access *what data*, not *what operations* may be performed on that data. A user with legitimate access can still misuse the data through legitimate API calls.

The technical literature does not adequately address the problem of **preventing doctrine violations at the moment of attempted commit** in a manner that is auditable, replayable, and resistant to incremental drift over time.

Specific technical gaps

(a) **No prior system, to the inventor's knowledge, gates every write operation in a multi-tenant hospitality data platform against an executable representation of declared ethical principles.** Where pre-commit hooks exist (e.g., Git pre-commit hooks), they validate code style or test coverage, not data-content compliance with declared ethical doctrine.

(b) **No prior system, to the inventor's knowledge, combines append-only event sourcing with doctrine-compliance metadata** in a manner that allows a third-party auditor to reconstruct, at any historical moment, both *what was done* and *which version of doctrine was in effect when it was done*.

(c) **No prior system, to the inventor's knowledge, exposes the doctrine-compliance gate as a versioned API surface** such that the doctrine itself becomes a first-class deployable artifact — versioned, tested, and rolled back in the same manner as code.

(d) **Existing privacy-by-design frameworks (e.g., GDPR Article 25) define principles** but do not specify mechanical enforcement architectures for AI service platforms.

The invention disclosed herein addresses each of these gaps.

Brief Summary of the Invention

A system and method are described in which a behavioral doctrine, expressed as a set of executable predicates over operations and data, is enforced as a pre-commit gate on all state-changing operations in a multi-tenant AI service platform. Every attempted write is evaluated against the current version of the doctrine; non-compliant writes are rejected at the data layer, before persistence, with the rejection recorded as an auditable event. Compliant writes are persisted to an append-only event log along with a cryptographic hash of the doctrine version under which they were validated, enabling later forensic replay and verification.

In one embodiment, the doctrine includes (among other principles):

- A capture-by-observation tenet that prohibits collection of guest data through interrogative interfaces;
- A score-persists-audio-evaporates tenet that imposes automatic expiry on raw audio while permitting derived inferences to persist;
- A tone-informs-care-never-commerce tenet that compile-time-prohibits certain code paths from importing certain data classes;
- A sensitive-flags-decay tenet that imposes automatic time-based decay on data fields tagged as psychologically sensitive;
- A forbidden-uses tenet that statically prohibits the use of specified data classes for specified purposes (e.g., advertising, third-party sharing, dynamic pricing).

The system further includes a retrospective replay engine that, given a candidate alternate doctrine, computes the counterfactual outcome that would have obtained had the alternate doctrine been in effect. This enables governance review, regulatory response, and continuous doctrine refinement.

The system further includes a cross-correlation engine that surfaces patterns where individually-compliant operations collectively suggest doctrine drift — for example, where a series of permitted small disclosures aggregates to a prohibited large disclosure.

The architecture is novel in that it treats ethical doctrine not as prose policy but as a versioned executable artifact, deployed, tested, and rolled back through the same engineering pipeline as application code.

Brief Description of the Drawings

[Note for counsel: Drawings to be prepared by a patent illustrator prior to non-provisional filing. Provisional may be filed without formal drawings but with informal sketches per 37 CFR 1.84.]

The following figures are referenced in the detailed description:

- **FIG. 1** — System architecture overview showing client devices, application services, doctrine gate, append-only event log, and doctrine registry.
- **FIG. 2** — Sequence diagram of a write operation passing through the doctrine gate, with branching into compliant-persisted, non-compliant-rejected, and non-compliant-with-override paths.
- **FIG. 3** — Schema of the doctrine registry, showing tenets, versioning, predicate definitions, and severity tiers.
- **FIG. 4** — Schema of the append-only event record, showing payload, doctrine-version hash, compliance result, and tenant isolation key.
- **FIG. 5** — Cross-correlation engine block diagram showing individual-compliance verification, aggregation, and drift signal emission.
- **FIG. 6** — Sensitive-flag decay timeline illustrating creation, decay-window, decay-trigger, and tombstone-record persistence.
- **FIG. 7** — Compile-time forbidden-path partition diagram showing static-analysis rejection of disallowed import graphs.
- **FIG. 8** — Monte Carlo counterfactual replay engine block diagram.
- **FIG. 9** — LLM-as-extractor active learning loop, illustrating confidence threshold, doctrine-gated correction persistence, and per-tenant template patches.
- **FIG. 10** — Forensic replay user interface mockup showing reconstruction of historical state with doctrine version pinned.

Detailed Description of the Invention

1. System architecture

Referring to FIG. 1, a multi-tenant AI service platform comprises:

- One or more **client devices** (mobile applications, kiosk applications, voice-enabled wearables, kitchen displays, etc.) that generate state-changing requests on behalf of authenticated users (guests, employees, operators).
- A **service layer** comprising a plurality of microservices or monolithic service modules implementing distinct business functions (reservations, kitchen production, payroll, concierge, voice analysis, etc.).
- A **doctrine gate** disposed between the service layer and the persistence layer, configured to receive every attempted write, evaluate the write against the current doctrine, and either permit or reject the write.
- An **append-only event log** acting as the system of record for all state-changing operations, in which each event record includes a cryptographic hash of the doctrine version under which the event was validated.
- A **doctrine registry** storing the canonical doctrine, comprising a versioned, signed, and replayable artifact.
- A **retrospective replay engine** capable of reconstructing historical state and computing counterfactual outcomes under alternate doctrines.
- A **cross-correlation engine** capable of identifying patterns of individually-compliant operations that collectively indicate doctrine drift.
- A **decay enforcement module** that applies time-based deletion or tombstoning to data fields tagged as decay-eligible.

2. The doctrine and its representation

The doctrine, in one embodiment, comprises a set of **tenets**, each of which is expressed as one or more executable predicates over candidate write operations. A tenet has, among other fields:

- a `tenet_id` (canonical identifier);
- a `version` (semantic version of this tenet);
- a `severity` (one of *blocking*, *warning*, *informational*);
- a `predicate` (an executable function returning compliance result);
- a `human_readable_text` (the doctrine as it appears to humans);
- an `effective_at` (date from which this tenet version applies);

- a `superseded_by` (reference to the tenet version that replaced this one, if any);
- a `signature` (cryptographic signature of the doctrine maintainer).

In one embodiment, tenets include but are not limited to:

Tenet A — Capture by observation, not interrogation

Predicate: `not exists(ui_surface that requests guest preference data through an interrogative form)`. Operationally enforced as a build-time lint that scans UI component definitions for forbidden patterns (e.g., star-rating widgets bound to guest profile mutations).

Tenet B — Score persists, audio evaporates

Predicate: `for every audio_record(r): r.expires_at <= r.created_at + 24h unless r.opt_in == true`. Operationally enforced at the moment of audio persistence; the doctrine gate rejects any audio insert lacking a compliant `expires_at`.

Tenet C — Tone informs care, never commerce

Predicate: `not (any function in {pricing, sales, marketing}.imports the symbol resonance_score)`. Operationally enforced as a static import-graph analysis at build time; CI fails if the import appears.

Tenet D — Trust score is invisible

Predicate: `for every UI render(r): r.payload does not include trust_score`. Operationally enforced at the API boundary; the doctrine gate strips `trust_score` from any payload destined for a client device.

Tenet E — Guest controls are first-class

Predicate: `every tenant exposes the four endpoints {what_we_remember, pause, delete_everything, export}`. Operationally enforced at deploy time; deployment fails if the four endpoints are not present.

Tenet F — Sensitive flags decay

Predicate: `for every flag(f) where f.class in {mental_health, family_tension, relationship_strain}: f.expires_at <= f.created_at + 30d unless explicitly_renewed(f)`. Operationally enforced by the decay module.

Tenet G — Forbidden uses

Predicate: `not (resonance_score, trust_score, voice_analysis used in {pricing_decision, third_party_share, advertising_target, profiling_beyond_service, external_model_training})`. Operationally enforced as both static-analysis and runtime gate.

The list above is illustrative, not exhaustive. The architecture admits arbitrary tenets so long as each has an executable predicate.

3. The doctrine gate

Referring to FIG. 2, a write operation proceeds as follows:

Step 2.1. A service in the service layer prepares a candidate event `E` representing the proposed state change. `E` includes a payload, a tenant identifier, an actor identifier, a timestamp, and a write-intent classifier.

Step 2.2. The service submits `E` to the doctrine gate.

Step 2.3. The doctrine gate retrieves the current doctrine version `D_current` from the doctrine registry.

Step 2.4. The doctrine gate evaluates each tenet in `D_current` whose predicate applies to events of `E` 's write-intent classifier. Evaluation may include: - Inspecting `E.payload` for prohibited fields; - Inspecting `E.actor` for prohibited roles; - Inspecting the call stack for prohibited import paths (where runtime introspection is available); - Querying the cross-correlation engine for drift-pattern hits; - Inspecting the decay registry for decay-window expirations.

Step 2.5. The doctrine gate produces a `compliance_result` record comprising: - an overall `permitted` boolean; - a list of `tenet_evaluations` , each with `tenet_id` , `passed` , `severity` , and `evidence` ; - the `doctrine_version_hash` under which evaluation occurred.

Step 2.6. If `permitted` is true, `E` is persisted to the append-only event log along with `compliance_result` . If false, `E` is **not** persisted; instead a `rejected_event` record is persisted to a separate doctrine-rejection log along with `compliance_result` , the proposed payload, and the actor identity.

Step 2.7. A response is returned to the calling service indicating permitted or rejected, with rejection responses including the failed tenet identifiers and human-readable justification.

A novel feature of the present invention is that **rejected writes are themselves persisted as auditable events**, enabling forensic investigation of attempted violations without storing the rejected payload data outside the rejection log (which itself may be subject to stricter access controls and retention).

4. The append-only event log

Referring to FIG. 4, each event record persisted to the append-only event log comprises, in one embodiment:

- `event_id` — globally unique identifier;
- `tenant_id` — multi-tenant isolation key, indexed;
- `actor_id` — identity of the principal who initiated the write;
- `event_type` — semantic type of the event;
- `payload` — the data being recorded;
- `timestamp` — wall-clock time of persistence;

- `doctrine_version_hash` — cryptographic hash of the doctrine version under which the event was validated;
- `compliance_signature` — signature of the doctrine gate attesting that the event passed compliance evaluation;
- `decay_at` — for events containing decay-eligible fields, the timestamp at which decay-tombstoning is required;
- `correlation_keys` — fields used by the cross-correlation engine to associate this event with a behavioral pattern.

The log is append-only; events cannot be modified or deleted in place. Decay and deletion are performed by writing tombstone events that override the prior event for purposes of read-time reconstruction, while leaving the original event in the log for forensic purposes (subject to the user's right-to-deletion rights, which are honored by encrypting the original payload and discarding the encryption key — see §7).

The cryptographic linkage between events and doctrine versions permits a third-party auditor to verify, for any historical event, the exact doctrine version under which that event was validated and to re-execute the doctrine predicates against the event payload to verify that the original validation was correct.

5. The retrospective replay engine

Referring to FIG. 8, the retrospective replay engine accepts as input: - a starting timestamp `t_0`; - an ending timestamp `t_1`; - a candidate alternate doctrine `D_alt`; - optionally, a tenant filter or actor filter.

The engine then: - Iterates over all events in the append-only event log within `[t_0, t_1]` (subject to filters); - Re-evaluates each event under `D_alt`; - Produces a counterfactual outcome report comprising: - the count of events that would have been rejected under `D_alt` that were permitted under the actual historical doctrine; - the count of events that would have been permitted under `D_alt` that were rejected; - the divergence trajectory over time; - per-tenet contribution to divergence.

In a particular embodiment, the engine performs Monte Carlo counterfactual replay by stochastically perturbing the actor or payload distributions to estimate the variance of outcomes under `D_alt`, providing governance reviewers with a robustness measure.

6. The cross-correlation engine

Referring to FIG. 5, the cross-correlation engine continuously scans the append-only event log for patterns where: - individually, each event is doctrine-compliant; - collectively, the pattern of events suggests doctrine drift.

Examples of such patterns include but are not limited to: - Aggregation drift: a series of permitted small disclosures aggregating to a prohibited large disclosure; - Role drift: a single principal performing a sequence of operations each individually permitted but together exceeding the principal's intended scope; - Temporal drift: a class of operations whose individual rate has not changed but whose tenant-aggregate rate has accelerated.

When a drift pattern is detected, the engine emits a `drift_signal` event into the append-only event log, which may be configured to trigger automated mitigations (e.g., temporary blocking of the pattern), human-in-the-loop review, or both.

7. The decay enforcement module

Referring to FIG. 6, the decay enforcement module applies to data fields tagged as decay-eligible. Each such field carries, at creation, a `decay_at` timestamp. A background process continuously scans for fields whose `decay_at` is less than the current time and:

- In the conservative embodiment, encrypts the field's payload with a per-field key and writes a tombstone event recording the decay; the encryption key is then discarded, rendering the original payload cryptographically inaccessible while preserving the event-log invariants.
- In the more aggressive embodiment, replaces the field payload with a null sentinel and writes a tombstone event.

Decay-tombstoning is itself a doctrine-gated operation; the tombstone is rejected if it would violate, e.g., a regulatory retention requirement, in which case the system surfaces the conflict to a human reviewer.

8. The compile-time forbidden-path partition

Referring to FIG. 7, the compile-time forbidden-path partition is a static-analysis pass that runs as part of the platform's continuous integration pipeline. It analyzes the import graph of the entire codebase and rejects any build in which: - a module designated as belonging to a forbidden category (e.g., `pricing`, `advertising`, `marketing_outbound`) imports, directly or transitively, a symbol designated as belonging to a protected category (e.g., `resonance_score`, `trust_score`, `voice_analysis`).

The forbidden-category and protected-category designations are themselves part of the doctrine registry, versioned and signed.

This static-analysis approach provides a stronger guarantee than runtime gating: it guarantees that the prohibited code path **cannot exist in the deployed binary**, not merely that it would be detected if executed.

9. The LLM-as-extractor active learning loop (related invention)

Referring to FIG. 9, in embodiments where the platform uses large language models for data extraction (for example, extracting structured invoice data from invoice images), the LLM operates within a doctrine-gated active learning loop:

- Each extraction is performed at a confidence threshold;
- Below the threshold, the extraction is held in a pending state rather than persisted;

- A human reviewer corrects the extraction;
- The correction is submitted to the doctrine gate for compliance review;
- If permitted, the correction is both (a) persisted as the final extraction and (b) used to update a per-tenant template patch that improves future extractions for that vendor or context;
- The template patch is itself doctrine-gated, ensuring that learning cannot incorporate prohibited correlations.

10. Multi-tenant isolation

Throughout the architecture, multi-tenant isolation is enforced by requiring a `tenant_id` on every event, indexed on every read query, and contract-tested at every API boundary. The doctrine gate is itself parameterized by tenant; tenants may inherit a base doctrine or carry tenant-specific extensions, subject to the constraint that no tenant doctrine may relax a base-doctrine tenet (only tighten it).

11. Versioning and rollback

The doctrine registry maintains all historical doctrine versions. The deployment of a new doctrine version is itself a state-changing operation, gated by a meta-doctrine that requires: - cryptographic signature by an authorized doctrine maintainer; - successful execution of the retrospective replay engine on the most recent N days of events under the proposed new doctrine, with a human-reviewed report of any divergences exceeding a threshold; - explicit acknowledgement that the new version takes effect at a specified `effective_at` timestamp.

Rollback is symmetric: the previous doctrine version is reinstated through the same gated process.

This versioning architecture enables the doctrine itself to be treated as a deployable artifact with the same rigor as application code, while preserving auditability of every decision against the doctrine version under which it was made.

Claims

[Note for counsel: claims are the legal heart of the patent. The following are draft claims for negotiation. Counsel should evaluate each against the prior-art search and revise scope accordingly.]

Independent Claims

Claim 1. A computer-implemented method for enforcing behavioral doctrine compliance in a multi-tenant artificial-intelligence service platform, the method comprising:

- storing, in a doctrine registry, a versioned doctrine comprising a plurality of tenets, each tenet comprising at least an executable predicate, a severity classifier, and a cryptographic signature;

- receiving, at a doctrine gate disposed between a service layer and a persistence layer of the platform, a candidate write event representing a state-changing operation, the candidate write event comprising at least a payload, a tenant identifier, an actor identifier, and a write-intent classifier;
- evaluating, by the doctrine gate, the candidate write event against the executable predicates of one or more tenets of a current version of the doctrine;
- determining, by the doctrine gate, whether the candidate write event is permitted under the current version of the doctrine;
- if the candidate write event is determined to be permitted, persisting the candidate write event to an append-only event log along with a cryptographic hash of the current version of the doctrine; and
- if the candidate write event is determined to be not permitted, persisting a rejection record to a doctrine-rejection log along with the cryptographic hash, and returning a rejection response to the service layer that identifies the failed tenets.

Claim 2. A system comprising:

- a service layer comprising one or more service modules implementing service-industry business functions;
- a doctrine registry storing a versioned doctrine comprising a plurality of tenets, each tenet comprising at least an executable predicate;
- a doctrine gate disposed between the service layer and a persistence layer, configured to receive candidate write events from the service layer, evaluate the candidate write events against the doctrine, and conditionally persist the candidate write events to an append-only event log;
- the append-only event log, comprising a plurality of event records, each event record comprising at least a payload, a tenant identifier, and a cryptographic hash of the doctrine version under which the event record was validated;
- a retrospective replay engine configured to reconstruct historical state from the append-only event log under a candidate alternate doctrine and to produce a counterfactual outcome report; and
- a cross-correlation engine configured to detect patterns of individually-compliant events that collectively indicate doctrine drift.

Claim 3. A non-transitory computer-readable medium storing instructions that, when executed by one or more processors, cause the processors to perform the method of Claim 1.

Dependent Claims

Claim 4. The method of Claim 1, wherein at least one tenet includes a predicate enforcing automatic time-based decay of data fields tagged as psychologically sensitive.

Claim 5. The method of Claim 1, wherein at least one tenet includes a predicate enforced by static analysis of an import graph of the platform's source code, the predicate prohibiting the import of specified symbols by specified modules.

Claim 6. The method of Claim 1, wherein the candidate write event comprises an audio recording, and wherein at least one tenet imposes an automatic expiry timestamp on audio recordings absent explicit user opt-in.

Claim 7. The method of Claim 1, further comprising: - receiving, at the retrospective replay engine, an alternate doctrine version; - re-evaluating, by the retrospective replay engine, a historical range of events under the alternate doctrine version; and - producing a counterfactual report identifying events that would have been rejected under the alternate doctrine but were permitted under the historical doctrine, and vice versa.

Claim 8. The method of Claim 1, wherein the doctrine gate is parameterized by tenant identifier and wherein each tenant may apply a tenant-specific doctrine extension that tightens, but does not relax, the base doctrine.

Claim 9. The method of Claim 1, wherein the cross-correlation engine is configured to detect aggregation drift, in which a sequence of individually-permitted small disclosures aggregates to an event that, evaluated as a unit, would have been prohibited.

Claim 10. The method of Claim 1, wherein deployment of a new doctrine version is itself a state-changing operation gated by a meta-doctrine that requires: - cryptographic signature by an authorized doctrine maintainer; - successful execution of the retrospective replay engine on a recent historical window with a human-reviewed report of divergences exceeding a configurable threshold; and - an explicit `effective_at` timestamp.

Claim 11. The system of Claim 2, further comprising a decay enforcement module configured to scan the append-only event log for events containing decay-eligible fields whose decay-window has elapsed and to write tombstone events that render the decayed fields cryptographically inaccessible while preserving event-log invariants.

Claim 12. The system of Claim 2, further comprising a large-language-model extraction module configured to extract structured data from unstructured inputs, wherein extractions below a confidence threshold are held in a pending state until corrected by a human reviewer, and wherein corrections are submitted through the doctrine gate prior to persistence.

Claim 13. The method of Claim 1, wherein the rejection record includes the proposed payload but is stored under stricter access controls and shorter retention than the permitted-event log.

Claim 14. The method of Claim 1, wherein the platform mediates hospitality service interactions including at least one of: restaurant operations, hotel operations, banquet operations, concierge services, and spa services.

Claim 15. The method of Claim 1, wherein the doctrine includes a tenet prohibiting the use of voice tone analysis, behavioral score inference, or trust score inference for any of: pricing decisions, advertising targeting, third-party data sharing, psychological profiling beyond the immediate service interaction, or training of machine-learning models for use outside the platform.

Abstract

A multi-tenant artificial-intelligence service platform enforces behavioral doctrine compliance through a pre-commit doctrine gate that evaluates every state-changing operation against a versioned, cryptographically-signed executable doctrine prior to persistence. Permitted operations are recorded in an append-only event log along with a hash of the doctrine version under which they were validated, enabling later forensic replay and audit. Rejected operations are recorded separately. A retrospective replay engine permits counterfactual analysis under alternate doctrine versions. A cross-correlation engine detects patterns of individually-compliant operations that collectively indicate doctrine drift. The architecture treats ethical doctrine as a versioned deployable artifact subject to the same engineering rigor as application code, addressing the conventional gap between policy commitments and technical enforcement in AI service platforms. (149 words.)

Inventor and Assignee Information

[To be filled in by the inventor before counsel review.]

- **Inventor name(s):** _________
- **Inventor address:** _________
- **Inventor citizenship:** ___________
- **Assignee:** Aurion Holdings, Inc. (or current legal entity name)
- **Assignee address:** _________
- **Assignment recorded:** Yes / No / Pending

[Note for counsel: confirm assignment is in place before filing non-provisional. Inventor-employee assignment agreements should be on file with the assignee.]

Suggested Filing Strategy (for counsel discussion)

1. **File this as a provisional today** to lock in the priority date.
2. **Within 90 days,** conduct a formal prior-art search through counsel; revise specification and claims based on findings.

3. **Within 6 months,** draft the non-provisional with formal drawings, narrowing or broadening claims as the prior-art search indicates.
4. **At 11 months,** convert to non-provisional and consider PCT filing for international protection.
5. **Plan continuations** for the six related inventions identified in §0.

Trade-Secret Inventory (NOT to be disclosed in this patent)

The following implementation details, in counsel's discretion, may be more valuable as **trade secrets** than as patent disclosures. They are listed here for the inventor's reference and **must not be included in the patent application as filed**:

- Specific predicate implementations for each tenet (the patent describes the *architecture* for predicates; the *exact code* is trade secret);
- Specific correlation heuristics used by the drift detector;
- Specific decay rate parameters for sensitive flag classes;
- Specific confidence thresholds for the LLM extraction loop;
- Specific prompt scaffolding used with the LLM;
- Specific tenant-isolation key derivation algorithm;
- Specific audit-log encryption key management.

These items should be protected by: - NDA with all employees and contractors who have access; - Access controls limiting visibility to need-to-know; - Marking source code with "TRADE SECRET — DO NOT DISTRIBUTE"; - Including in the company's trade-secret inventory document required for misappropriation claims (per Defend Trade Secrets Act, 18 U.S.C. § 1836).

Document Status

- **Draft prepared:** 2026-05-08
- **Drafted by:** Claude (Anthropic AI assistant) at inventor's request, working from the codebase at `Echo_Aurion-LUCCCA_Framework`, primarily from `PRIVACY_TENETS.md` and `docs/maestro/THE_LINE.md`.
- **Status:** DRAFT — for attorney review only. Not legal advice. Not to be filed without counsel.
- **Next action:** Send to a licensed United States patent attorney with experience in software / AI / privacy patent prosecution.

End of Document

P1 · IP Assignment Packet

P.1 — IP Assignment Packet

> ***DRAFT TEMPLATES — REVIEW WITH A LICENSED ATTORNEY BEFORE SIGNING.*** *These are starting points so a corporate / IP attorney can fast-track the work. Use a Delaware C-corp lawyer for the final paperwork.*

Why this is the #1 institutional item

A 409A valuation, a patent filing, a strategic acquisition, and an investor's diligence pack all collapse the same way if the company doesn't clearly own its code, brands, and inventions. Without **signed IP assignment agreements** in place from every contributor (human or otherwise), there's no clean chain of title — and an acquirer will either price-cut you or walk.

For Echo / LUCCCA, the situation is unusually clean today:

· **One human contributor** (you) directing all work · **AI assistants** that don't own anything they generate (per US Copyright Office 2023 guidance — AI-generated content lacks human authorship and isn't copyrightable; the human directing the AI is the "creative force" who owns the output) · A **draft patent application** that needs your name as the sole inventor

What you sign this week: 1. A **Founder IP Assignment + Confidentiality Agreement** — assigns all your prior work-product to the company. This is usually called a "Confidential Information and Inventions Assignment" (CIIA) when used for employees, but the founder version covers the pre-incorporation period too. 2. A **Pre-Incorporation IP Assignment** — captures any work you did BEFORE the company was formed (most likely some of this codebase) and assigns it to the company retroactively.

You don't need anything from the AI (it owns nothing). When you add a second human contributor — employee or contractor — they sign: 3. **Employee CIIA** (for full-time hires) 4. **Independent Contractor IP Assignment** (for contractors)

Why AI contributors don't change the IP picture

The US Copyright Office's August 2023 guidance is clear: *"works generated by artificial intelligence without human authorship are not eligible for copyright protection."* If a human directs the AI substantively — choosing prompts, reviewing outputs, accepting or rejecting drafts, integrating outputs into a larger creative whole — the **human is the author** and owns the work product.

For patent law, the Federal Circuit (*Thaler v. Vidal*, 2022) ruled that AI cannot be a named inventor. The human inventor (you) is the named inventor on any patent application; AI tools are tools, the same way Photoshop is a tool for a graphic designer.

Practical consequence: when you assign your work to the company via the founder agreement below, **all the AI-assisted code, the patent draft, the doctrine framework, the icon master list, the upgrade strategy doc — everything — flows to the company.** The AI didn't need to sign anything because the AI never owned anything.

You should still **document** the AI assistance for honesty (see the AI Contribution Disclosure section below), but it doesn't require additional paperwork.

Document 1 — Founder IP Assignment + Confidentiality Agreement (CIIA)

> ***Template — replace bracketed fields. Have an attorney review before signing.***

```
CONFIDENTIAL INFORMATION AND INVENTIONS ASSIGNMENT AGREEMENT
(Founder Version – Aurion Holdings, Inc.)

This Agreement is entered into as of [DATE], by and between
Aurion Holdings, Inc., a Delaware corporation (the "Company"),
and William Morrison ("Founder"), an individual residing at
[ADDRESS].

In consideration of Founder's continuing relationship with the
Company, including without limitation Founder's services as an
employee, officer, director, and/or stockholder of the Company,
and other valuable consideration, the receipt and sufficiency
of which are hereby acknowledged, Founder agrees as follows:

1. CONFIDENTIAL INFORMATION
1.1 Definition. "Confidential Information" means any information
that is or has been disclosed to Founder by the Company or
otherwise known to Founder as a consequence of Founder's
relationship with the Company, including without limitation:
   (a) The Company's products, services, know-how, inventions,
       trade secrets, ideas, proprietary information, including
       the doctrine framework, the lifecycle engine, the outlet
       capture system, the trial-level retrospective with signal
       attribution, the intercompany eliminations engine, the
       upgrade safety infrastructure, the icon master list, and
```

```
       any other intellectual property of the Company;
   (b) Information about customers, suppliers, employees, and
       prospects;
   (c) Financial information, business strategies, marketing plans,
       pricing, costs, and product roadmaps;
   (d) The patent application drafts, trade-secret inventory, and
       brand guidelines;
   (e) The Privacy Tenets, the doctrine documents, and the
       brigade methodology.

1.2 Non-Disclosure. Founder agrees to hold all Confidential
Information in strict confidence and shall not disclose it to any
third party without prior written consent of the Company, except
as required by law or court order.

1.3 No Reverse Engineering. Founder shall not reverse engineer,
decompile, or disassemble any Confidential Information.

1.4 Return of Materials. Upon termination of Founder's relationship
with the Company, Founder shall promptly return all Confidential
Information and all copies thereof to the Company.

2. ASSIGNMENT OF INVENTIONS
2.1 Disclosure. Founder shall promptly disclose to the Company in
writing all inventions, discoveries, designs, developments, methods,
modifications, improvements, processes, algorithms, databases,
computer programs, software (including source code and object
code), formulae, techniques, trade secrets, graphics or images,
audio or visual works, and other works of authorship (collectively,
"Inventions") conceived, developed, made, or reduced to practice
by Founder, alone or jointly with others, during the term of
Founder's relationship with the Company.

2.2 Assignment. Founder hereby assigns and agrees to assign to
the Company all right, title, and interest worldwide in and to
all Inventions and any associated intellectual property rights,
including patents, copyrights, trademarks, trade secrets, and
moral rights, that:
   (a) Relate to the Company's actual or anticipated business,
       research, or development;
   (b) Result from any work performed by Founder for the Company;
   (c) Use, incorporate, or were conceived using any of the
       Company's resources, equipment, facilities, supplies,
       Confidential Information, or time of any Company employee;
       OR
   (d) Were conceived, developed, made, or reduced to practice
       by Founder during the period of Founder's relationship
       with the Company.

2.3 AI-Assisted Work. Founder confirms that any work product
generated with the assistance of artificial intelligence systems
```

```
(including but not limited to large language models, code
generators, and image generators) under Founder's direction and
creative control is owned by Founder pursuant to applicable law,
including U.S. Copyright Office guidance regarding works of human
authorship, and is hereby assigned to the Company under this
Section 2.

2.4 Pre-Incorporation Inventions. Without limiting the foregoing,
Founder hereby assigns to the Company all right, title, and
interest in all Inventions conceived, developed, made, or reduced
to practice by Founder prior to the date of incorporation of the
Company that relate to the Company's business, research, or
development, including but not limited to: the codebase commits
authored by Founder before the Company's formation, the doctrine
framework drafts, the icon designs, the patent drafts, the
business plans, the brand identity, and the customer lists. A
non-exhaustive list of pre-incorporation Inventions assigned
hereby is attached as **Exhibit A**.

2.5 Power of Attorney. Founder appoints the Company as Founder's
attorney-in-fact to execute documents necessary to effectuate the
assignments set forth in this Section 2.

2.6 Moral Rights. To the extent allowed by law, Section 2.2
includes a waiver of any moral rights Founder may have in any
Inventions.

3. EXCLUDED INVENTIONS
The Inventions listed in **Exhibit B** ("Excluded Inventions")
are pre-existing intellectual property of Founder that are NOT
assigned to the Company. If Exhibit B is left blank or marked
"None," Founder represents that there are no Excluded Inventions.

4. CALIFORNIA LABOR CODE § 2870 NOTICE
[If Founder is a California resident at any time, this provision
notifies Founder of the carve-out under California Labor Code
§ 2870. Other states have analogous provisions. Counsel will tailor
to the actual state of residence.]

5. NO CONFLICTING OBLIGATIONS
Founder represents that Founder has no agreements with any prior
employer or third party that would prohibit or restrict Founder's
ability to enter into this Agreement and assign Inventions to
the Company.

6. NON-SOLICITATION
[Standard 12-month non-solicitation of employees + customers,
subject to applicable state law.]

7. RETURN OF PROPERTY
Upon termination, Founder shall promptly return all Company
```

```
property, including all materials containing Confidential
Information.

8. AT-WILL RELATIONSHIP
Nothing in this Agreement creates an employment relationship of
any specific duration; Founder's relationship with the Company is
at-will and may be terminated by either party at any time.

9. EQUITABLE RELIEF
Founder acknowledges that the Company would be irreparably
harmed by a breach of this Agreement and that monetary damages
would be inadequate. The Company is entitled to seek equitable
relief, including injunctive relief, in addition to any other
available remedies.

10. GENERAL PROVISIONS
10.1 Governing Law. This Agreement is governed by the laws of
the State of Delaware, without regard to its conflict of laws
principles.
10.2 Entire Agreement. This Agreement constitutes the entire
agreement of the parties with respect to its subject matter.
10.3 Severability. If any provision is unenforceable, the
remaining provisions shall remain in effect.
10.4 Counterparts. This Agreement may be executed in counterparts,
including by electronic signature.

IN WITNESS WHEREOF, the parties have executed this Agreement as
of the date first above written.

AURION HOLDINGS, INC.

By: ____________________________
Name: _________________________
Title: _________________________

FOUNDER

By: ____________________________
Name: William Morrison
Date: _________________________

---

EXHIBIT A — PRE-INCORPORATION INVENTIONS ASSIGNED

The following pre-incorporation Inventions are hereby assigned to
the Company under Section 2.4:

1. The Echo / LUCCCA platform codebase, including all commits
   authored by Founder in the wmorrison76/Echo_Aurion-LUCCCA_Framework
   GitHub repository as of [DATE].
```

```
2. The doctrine framework documents, including PRIVACY_TENETS.md,
   THE_LINE.md, NO_PLACEHOLDER_POLICY.md, SERVICE_RECOVERY.md,
   and all related brigade methodology documents.
3. The icon master list, brand identity guidelines, and all
   commissioned brand assets.
4. The provisional patent application draft titled "System and
   Method for Code-Enforced Behavioral Doctrine Compliance in
   Multi-Tenant Service-Industry AI Platforms" and all related
   trade-secret inventory.
5. The customer lists, prospect lists, and business plans
   developed by Founder prior to incorporation.
6. The lifecycle engine + 8 hospitality lifecycle templates.
7. The CFO toolkit modules, outlet capture system, intercompany
   eliminations engine, upgrade safety infrastructure, and all
   related documentation in the docs/ directory.

---

EXHIBIT B — EXCLUDED INVENTIONS

[None — Founder confirms no pre-existing inventions are excluded.]

OR list any pre-existing inventions Founder owns separately
that are NOT being assigned to the Company.
```

Document 2 — Employee CIIA Template (for future hires)

The Employee CIIA is a near-copy of the Founder version, with these adjustments:

· Section 2.2(c) — strengthens the "uses Company resources" hook because employees use Company laptops, accounts, and time · Section 2.4 — typically does NOT include pre-employment inventions assignment (since the company doesn't get pre-employment IP); replaced with an Exhibit listing any pre-existing inventions the employee retains · Section 4 — California § 2870 notice is more important here · Section 6 — non-solicit becomes more important · A separate offer letter usually accompanies the CIIA, including salary, equity grant, vesting schedule

The same Confidential Information section + AI-assisted-work clause apply.

When you make your first hire, your attorney will tailor the Employee CIIA. Plan for ~$500-1,500 of legal time for that first template; subsequent hires reuse it.

Document 3 — Independent Contractor IP Assignment

Contractors are different — they're not employees, so default "work for hire" doctrine doesn't always apply. The contractor agreement must explicitly:

· Define every deliverable as work-for-hire AND assign all rights to the company as a backup if work-for-hire doesn't apply · Include the same Confidential Information clauses · Include AI-assisted-work language · Carve out pre-existing tools the contractor uses (their own libraries, frameworks) so they retain rights to those

If you use platforms like Upwork, Toptal, or hire freelance designers/developers directly, **always** have them sign this before they start. The icons, the brand work, the patent illustrations when commissioned — all need this.

```
INDEPENDENT CONTRACTOR AGREEMENT
(IP-Assignment Version)

[STANDARD CONTRACT TERMS]

WORK PRODUCT
1. All work product, including but not limited to designs, code,
   text, images, audio, video, AI-assisted output, models, data,
   and documentation (the "Work Product"), is created as work-
   made-for-hire for the Company under the U.S. Copyright Act.

2. To the extent any Work Product is not, by operation of law,
   work-made-for-hire, Contractor hereby irrevocably assigns to
   the Company all right, title, and interest in and to the Work
   Product, including all copyrights, patents, trade secrets,
   trademarks, and moral rights worldwide.

3. AI-Assisted Work. Where Contractor used AI tools to assist in
   creating Work Product, Contractor confirms that Contractor
   directed the creative process and is the "creative force" /
   author. Contractor hereby assigns the same rights as in
   Section 2 to the Work Product so generated.

4. Contractor's Pre-Existing Tools. Section 2 does not apply to
   Contractor's pre-existing tools, libraries, and templates that
   were developed prior to this engagement and are listed in
   Exhibit X. Contractor grants the Company a non-exclusive,
   perpetual, royalty-free license to use those pre-existing
   tools to the extent they are embedded in the Work Product.

5. Confidentiality + Non-Disclosure clauses parallel to the
   Founder CIIA.
```

Document 4 — AI Contribution Disclosure (for honesty + future audits)

Not a legal requirement, but a good-hygiene document:

```
AI CONTRIBUTION DISCLOSURE
(Aurion Holdings, Inc. — D64 release as of [DATE])

This disclosure documents the use of AI assistants in creating
work product owned by Aurion Holdings, Inc.

1. AI tools used:
   · Anthropic Claude (multiple model versions including
     Opus 4.7) — used for code generation, documentation drafts,
     architectural review, and analytical writing under the
     direction of Founder.

2. Scope of AI assistance:
   · The Founder directed all creative decisions including
     prompt design, architectural choices, doctrine framework,
     module boundaries, brand identity, and acceptance/rejection
     of AI-generated drafts.
   · The Founder reviewed every AI output, integrated outputs
     into a coherent system, and made the substantive design
     decisions.

3. Ownership:
   · Per U.S. Copyright Office guidance (August 2023) and
     Federal Circuit precedent (Thaler v. Vidal, 2022), AI tools
     do not own AI-generated outputs.
   · The Founder, as the directing creative force, is the
     author/inventor of all work product. All such work product
     has been or will be assigned to the Company per the Founder
     IP Assignment Agreement.

4. No AI-author claims:
   · The Company will not claim AI authorship in any copyright
     registration, patent application, or trademark filing.
   · Patent applications will name the Founder (and any other
     human contributor who is a true inventor) as the named
     inventor(s) under 35 U.S.C. § 100(f).

Signed: William Morrison, Founder
Date: ____________
```

What you do this week (concrete steps)

1. **Find a Delaware C-corp attorney.** Cooley, Gunderson, Goodwin Procter, Latham, Wilson Sonsini are the BigLaw choices ($600- 1,200/hr). For your stage, **Stripe Atlas Lawyers**, **Clerky**, or a boutique like **Founders Workbench** (free templates) / **OpenForms** is sufficient. Budget: $1,500-3,500 for the founder package.

2. **Gather the facts they'll ask for:** · Date of incorporation (your Aurion Holdings, Inc. cert) · Founder's full legal name, address, citizenship · Stock issuance to Founder (number of shares, par value, consideration paid) · A list of pre-incorporation inventions for Exhibit A — see Exhibit A above; you can use that as your draft
3. **Sign the Founder CIIA + Pre-Incorporation IP Assignment first.** This unblocks: · The patent provisional filing · The 409A valuation · Any future investor diligence
4. **Have the attorney prepare the Employee CIIA + Contractor IP Assignment templates.** Don't sign them yet — these get pulled out when you hire someone.
5. **File the AI Contribution Disclosure in the company records.** Not for the public — for your own audit trail.

Estimated cost + time

Item	Cost	Time
Founder CIIA + Pre-Incorp Assignment (drafted by attorney)	$1,500-2,500	5-10 days
Employee CIIA template (first version)	$500-1,000	3-5 days
Contractor IP Assignment template	$500-1,000	3-5 days
AI Contribution Disclosure	$0	30 minutes
Total	**$2,500-4,500**	**~2 weeks**

This is the cheapest single intervention that unlocks the most downstream value (patent, 409A, fundraise). Do it this month.

P3-P6 · Filing & Vendor Packet

P.3 + P.4 + P.5 + P.6 — Filing + Vendor Packet

> *Trademarks, SOC 2 prep, pen-test scope, 409A valuation vendors — all the items that need either a filing fee + a vendor or just a vendor relationship started. Each section ends with **what you sign, what it costs, and how long it takes.***

P.3 — Trademark Application Packet

Why now

Trademarks are filed *before* you launch publicly because:

· **Priority date** is set by filing, not by use. First-to-file in most countries; intent-to-use applications are valid in the US even without commercial use yet. · **A registered mark gives you teeth** — copycat operators get cease-and-desist letters; without the registration, you have only common-law protection in your geographic area. · **Investor diligence checks for it** — having marks pending or registered signals "the brand is defensible."

USPTO filing fee is $250-350 per class per mark (TEAS Standard or TEAS Plus). Attorney fees add $500-1,500 per mark. International filings via WIPO Madrid Protocol cost more (varies by country).

The 13 marks to file

For each mark, the **primary class** is shown plus the **goods/ services description** that the USPTO expects.

#	Mark	Primary class(es)	Goods/services description	Filing strategy
1	**EchoAurion** (the platform brand)	9, 35, 42	Software platform for hospitality operations management; SaaS platform; computer software for managing hotel and restaurant operations	1(b) intent-to-use; convert to 1(a) on launch
2	**LUCCCA** (the framework)	9, 42	Computer software framework; SaaS application development tools	1(b) ITU

#	Mark	Primary class(es)	Goods/services description	Filing strategy
3	**EchoAurum** (financial product)	9, 36, 42	Financial accounting software; financial management SaaS; financial planning and analysis tools	1(b) ITU
4	**EchoConcierge**	9, 35, 43	Concierge SaaS; hospitality concierge software; software for managing guest services in hotels	1(b) ITU
5	**EchoStratus**	9, 42	Cloud-intelligence software for hospitality; weather-aware operational software	1(b) ITU
6	**EchoCronos**	9, 35, 42	Time and shift management software; hospitality scheduling SaaS	1(b) ITU
7	**EchoConnect**	9, 42	Software integration platform; connector framework for hospitality systems	1(b) ITU
8	**EchoLayout**	9, 42	Event layout and floorplan design software	1(b) ITU
9	**EchoWaste**	9, 42	Waste tracking and sustainability SaaS for hospitality	1(b) ITU
10	**EchoEventStudio**	9, 35, 42	Event production software; banquet event management SaaS	1(b) ITU
11	**EchoCanvasStudio**	9, 42	Design canvas software for hospitality; brand canvas tools	1(b) ITU
12	**EchoAI³**	9, 42	Artificial intelligence software for hospitality operations; doctrine-enforcement AI tools	1(b) ITU
13	**The black-hat-with-gold-lettering logo** (design mark)	9, 35, 42	Same as EchoAurion — the design mark serves as the visual brand	1(b) ITU

Class meanings (USPTO Trademark Manual): · **Class 9** — software, downloadable computer programs · **Class 35** — business management services (consultancy, SaaS that manages business operations) · **Class 36** — financial services · **Class 41** — entertainment services · **Class 42** — SaaS / computer services / hosting · **Class 43** — hospitality services (food, beverage, accommodation)

For your platform, **9 + 42** are the must-haves. Class 35 covers business-management SaaS, Class 36 is needed for EchoAurum (financial), Class 43 is needed for EchoConcierge (hospitality services).

Filing strategies — 1(a) vs 1(b)

· **1(a) — Use in commerce.** You file with proof you're already selling the product/service under that mark. Lower fees, faster registration. Use this for marks where you've already launched. · **1(b) — Intent to use.** You file before launch with a sworn intent to use within the next 36 months (extensions available in 6-month chunks for up to 36 months total). Once you launch, you file a Statement of Use (SOU) and the registration completes.

For Echo / LUCCCA today, **most marks should be 1(b) ITU** because the platform isn't in commerce yet. As properties go live, switch the relevant marks to 1(a).

The filing checklist (per mark)

For each mark, your trademark attorney needs:

· The mark itself (text or design) · For design marks: a high-resolution image · The classes you want to file in · The goods/services description (template-able from above) · Proof of priority (none needed for ITU) · Specimen of use (only for 1(a) and at the SOU stage for 1(b)) · Date of first use (for 1(a)) · Owner (Aurion Holdings, Inc.) and signing authority

---

Total cost estimate

· USPTO fees: 13 marks × ~3 classes × $250-350/class = **$9,750- 13,650** (filed across all classes; you can reduce by filing fewer classes per mark, but at least 9 + 42 per mark is recommended for software brands) · Attorney fees: $500-1,500/mark × 13 = **$6,500-19,500** · International (WIPO Madrid Protocol — recommended for EchoAurion + LUCCCA at minimum): **$2,500-5,000 per mark per bloc of countries**

Realistic minimum to file all 13 in US: ~$15,000-25,000.

Phased approach (recommended): · Phase 1 — file the **top 4** (EchoAurion, LUCCCA, EchoAurum, EchoConcierge) in classes 9 + 42: ~$5,000-8,000. · Phase 2 — file the remaining **9 marks**: ~$10,000-17,000 over next 6 months. · Phase 3 — Madrid Protocol for the top 4 once you have funding or a foreign customer.

Recommended trademark attorneys / services

· **LegalZoom / Trademark Engine** — DIY-ish at $200-500/mark plus filing fees. Fine for the simpler marks. · **USPTO TEAS Plus** direct filing (no attorney) — $250/class. Risky for complex marks; attorney recommended for novel words like LUCCCA where the spelling needs care. · **Cooley / Wilson Sonsini / Gunderson** — BigLaw, $1,000-1,500/mark. Investor-respected. · **Boutique trademark firms (Gerben Law, Trademarkia)** —

$500-1,000/mark. Good middle ground. · **Stripe Atlas trademarks** — bundled with their startup- formation tier; good for the first 1-2 marks.

P.4 — SOC 2 Prep Packet

What SOC 2 is

A **SOC 2** report is an independent auditor's attestation that your company has implemented and follows a defined set of security controls. It's the standard hospitality chains, banks, and enterprise customers ask for before they sign a contract.

There are two flavors:

· **SOC 2 Type I** — point-in-time snapshot. "On [date], the company had these controls in place." Shorter to obtain (3-6 months of evidence + 30-90 day audit). Cheaper. Less valuable. · **SOC 2 Type II** — operational period. "Over [period of 6-12 months], the company operated these controls effectively." Longer to obtain. More valuable. Most enterprise customers require Type II.

Recommendation: start with Type I within 6 months, target Type II within 18 months. Type I evidence collection IS Type II evidence collection — they overlap.

The five Trust Services Criteria

SOC 2 covers up to five "Trust Services Criteria" (TSCs). You choose which to include in scope. For a hospitality SaaS:

· **CC (Common Criteria) — REQUIRED.** Security baseline. Always in scope. · **A (Availability)** — Recommended for SaaS. Customers expect the service to be up. · **C (Confidentiality)** — Recommended. Customer data protection. · **P (Privacy)** — Recommended. Especially with the Privacy Tenets you've built. · **PI (Processing Integrity)** — Recommended for financial SaaS. Aurum + the GL guardians make a strong case.

Suggested scope for Echo / LUCCCA: CC + A + C + P + PI.

What's already in place (much more than most pre-seed companies)

The doctrine framework + the codebase already cover many SOC 2 common-criteria controls without realizing it:

Control area	What you already have
CC1 — Control Environment	Doctrine framework, brigade methodology, NO_PLACEHOLDER_POLICY

Control area	What you already have
CC2 — Communication & Information	Privacy Tenets, transparent failure mode reporting, doctrine §1.1
CC3 — Risk Assessment	Doctrine-as-code analysis pre-commit, regime-change escalation
CC4 — Monitoring	Append-only event log, daily audit cron, accuracy gauge
CC5 — Control Activities	Pre-commit doctrine gate, forbidden-path partition, decay engine
CC6 — Logical Access	Multi-tenant isolation (D27), RBAC routes, admin_audit_log
CC7 — System Operations	Scheduler with named jobs, structured logging, canonical health, upgrade safety
CC8 — Change Management	Migration runner with checkpoints, schema version stamps, append-only history
CC9 — Risk Mitigation	Trade secret inventory, patent draft, decay engine, key shredding

Vendor comparison — compliance automation platforms

These platforms automate ~70% of the evidence collection. **Use one — don't try to do this manually.**

Tool	Pricing	Best for	Notes
Vanta	$14k-30k/yr (incl. all frameworks)	Most popular; best UX	The default choice for VC-backed startups. Auto-collects from AWS, Mongo, GitHub, Okta, etc.
Drata	$7k-30k/yr	Closest competitor to Vanta	Slightly cheaper at entry; UX similar quality
Secureframe	$9k-25k/yr	Comparable	Strong in healthcare; works for hospitality too
Tugboat Logic (now OneTrust)	Custom	Enterprise-leaning	More expensive
Thoropass (formerly Laika)	Custom	Combined audit + automation	They include the audit, not just the prep

Recommendation: Vanta or Drata. Vanta if you want the brand recognition with future investors; Drata if you want the lower price point. Either is fine.

Vendor comparison — auditors

The auditor is separate from the prep platform. The platform collects evidence; the auditor reviews it and issues the report.

Auditor	Type	Best for
Schellman & Co	Big-4 alternative	Most-recognized SOC 2 + ISO 27001 auditor for SaaS
A-LIGN	Big-4 alternative	Comparable to Schellman; common choice
Prescient Assurance	Boutique	Cheaper; good for first-time audit
Linford & Co	Boutique	Specializes in startups
BDO / Crowe / RSM	Mid-tier accounting firms	More expensive but recognized
Big 4 (Deloitte, EY, PwC, KPMG)	n/a for early stage	Overkill until pre-IPO

Recommendation: Prescient Assurance or Linford for first-time Type I; upgrade to A-LIGN or Schellman for Type II.

Cost estimate (Type I, total program)

Item	Cost	Time
Vanta or Drata subscription	$7,000-15,000/yr	Day 1 setup (~3 days)
Auditor (Type I)	$15,000-30,000 one-time	30-90 day audit
Internal time (you)	n/a	~30-50 hours over 3-6 months
Total	**~$22,000-45,000**	**6-9 months from start to issued report**

For Type II: add another auditor pass at the 12-month mark (~$15-25k); the same Vanta/Drata subscription continues.

What you do this week

1. **Pick Vanta or Drata.** Sign up. They walk you through scoping.
2. **Choose the TSC scope** (CC + A + C + P + PI recommended).
3. **Set the start date** — most teams pick the 1st of the next month so the evidence-collection window is clean.
4. **Connect the integrations** — AWS, MongoDB Atlas, GitHub, Okta/Auth0, your password manager, etc. Vanta/Drata auto-collect from these.
5. **Engage an auditor in month 4-5** — they need to be lined up before the Type I window closes.

P.5 — Independent Pen-Test RFP

What a pen-test gets you

A penetration test is an authorized simulated attack on your platform, conducted by a security firm with experience in your technology stack. They try to:

· Bypass authentication · Escalate privileges · Access data they shouldn't (IDOR, broken access control) · Exfiltrate data · Inject code (XSS, SQLi) · Hijack sessions · DoS the service (light, with permission) · Identify supply-chain risks (vulnerable dependencies)

The deliverable is a **report** with findings categorized by severity (Critical, High, Medium, Low, Informational), each with a reproduction step and a remediation recommendation. Critical + High findings are remediated before public launch; Medium + Low are tracked for the next sprint.

When you need one

· **Before processing real payments** — required by PCI DSS and most enterprise contracts · **Before SOC 2 Type II** — typically required as part of CC9 (risk mitigation) · **Before any luxury hotel chain procurement** — they ask for it during diligence · **Before a Series A** — investors do their own technical diligence and a recent pen-test report makes it painless

Target window: 30-60 days before first revenue. Earlier is fine; later is risky.

Scope template (RFP-able)

Send the following to 3-4 vendors for quotes:

```
PENETRATION TEST RFP — Aurion Holdings, Inc. (Echo / LUCCCA Platform)

1. Engagement scope
   In-scope:
   · Web application (operator-facing): https://app.echoaurion.com
   · API (REST, all endpoints under /api/*): https://api.echoaurion.com
   · Authentication + session management
   · Multi-tenant isolation (verify tenant A cannot read tenant B)
   · Role-based access control (verify lower roles cannot access
     higher-role endpoints)
   · Privacy Tenet 4 enforcement (verify trust_score is never
     exposed to client-side responses)
   · Privacy Tenet 8 enforcement (verify forbidden imports are
     not present in deployed binary)
   · OWASP API Top 10
   · Common SaaS attacks (SSRF, deserialization, IDOR)
```

```
   Out-of-scope:
   · Physical attacks
   · Social engineering of employees (separate engagement if needed)
   · Customer-side property infrastructure (POS, PMS — those are
     vendor systems)
   · Denial-of-service beyond informational confirmation

2. Engagement methodology
   · Both unauthenticated and authenticated testing
   · Authenticated testing as: (a) operator user, (b) admin user,
     (c) employee user (lowest privilege), (d) tenant boundary
     test

3. Engagement length
   · 2-week engagement
   · Daily standup with our team during the engagement
   · 5-business-day report turnaround after engagement ends

4. Reporting
   · Executive summary (1-2 pages)
   · Detailed findings with severity ratings (CVSS v3.1)
   · Reproduction steps for each finding
   · Remediation recommendations
   · Re-test option for Critical + High findings (within 30 days
     of remediation)
   · Letter of attestation suitable for sharing with customers

5. Vendor questions for the RFP
   · Cost (daily rate × days, or fixed)
   · Lead time before engagement can start
   · Sample report (sanitized) we can review
   · References from comparable SaaS platforms
   · Insurance + bonding levels
   · NDA terms

6. Vendor evaluation criteria
   · Reputation in SaaS / multi-tenant assessments
   · Reporting quality
   · Cost competitiveness
   · Lead time
   · Sample report quality
```

Vendor comparison

Vendor	Tier	Approx cost (2-week engagement)	Notes
Bishop Fox	Tier 1	$40,000-80,000	Premium; well-known; thorough
NCC Group	Tier 1	$40,000-80,000	Premium; UK-based but US offices
Trail of Bits	Tier 1	$50,000-100,000	Strongest in cryptography + smart contracts; thorough
NetSPI	Tier 1.5	$30,000-60,000	Strong on web app testing
Cobalt	Tier 2 (crowdsourced)	$15,000-40,000	Pentest-as-a-service; faster turnaround
Hacken	Tier 2	$15,000-40,000	Good price/quality for SaaS
Synack	Tier 2 (crowdsourced)	$25,000-50,000	Continuous + scheduled options

Recommendation for first pen-test: NetSPI or Cobalt. NetSPI gives you a Tier-1 brand for diligence with a friendlier price; Cobalt is the cheapest credible option and tracks engagement over time.

Cost estimate

Item	Cost
First pen-test (Tier 1 firm)	$25,000-60,000
Re-test of remediated Criticals + Highs	$5,000-15,000 (often included)
Annual re-test (required for SOC 2 Type II)	Same as first
Total year 1	**$30,000-75,000**

P.6 — 409A Valuation Vendor Packet

What a 409A is (recap)

An **independent appraisal of your common stock's fair market value** to comply with IRS § 409A. Required to set option strike prices defensibly. Without it, employees risk 20% additional tax penalties on their option grants.

When to get one

· **Before granting first stock options** to a hire · **After every material event:** funding round, large business change, change of control, etc. · **At least every 12 months** for the appraisal to remain "safe harbor" valid

For Echo / LUCCCA today: **before the first option grant** and **at least every 12 months thereafter.**

Vendor comparison

Vendor	Bundled with cap table?	Cost	Turnaround
Carta 409A	Yes (with subscription)	$1,000-2,500	5-15 business days
Pulley 409A	Yes (with subscription)	$1,000-2,000	5-15 business days
AngelList Stack 409A	Yes (partner)	$1,000-2,000	10-15 business days
Aranca	Standalone	$5,000-10,000	3-4 weeks
Scalar	Standalone	$5,000-10,000	3-4 weeks
Andersen	Standalone	$7,000-15,000	3-4 weeks
Murphy McCann	Standalone	$5,000-12,000	3-4 weeks
Eqvista	Standalone or with subscription	$1,500-3,000	1-2 weeks

Recommendation

For your stage: bundle with Pulley or Carta. · Bundled 409As are produced by the same regulated appraisal firm as standalone — they're not lower quality · The cap table tool already has all your inputs (issued shares, option grants, financials) · Turnaround is faster · Cost is dramatically lower

Switch to a standalone (Aranca, Scalar) when: · You're closing a Series A/B and the valuation needs more depth than the bundled tool produces · An investor or acquirer specifically asks for an independent appraisal

Cost + time

Item	Cost	Time
First 409A (bundled with Pulley/Carta)	$1,000-2,500	5-15 business days
Annual refresh	Same	Same
Funding-round refresh	Same or standalone $5-10k	1-3 weeks
Total year 1	**$1,000-12,500 depending on funding events**	**~2 weeks per refresh**

Bonus — Additional founder operational items

Things you should also have lined up

#	Item	Cost	Time	Why
1	**EIN (Employer ID Number)** from IRS	$0	5 min	Required to open a bank account, hire anyone, file taxes
2	**Business bank account** (Mercury / Brex / JPMorgan)	$0	30 min	Required for company finances; Mercury is the most-popular SaaS-friendly choice
3	**Business credit card** (Brex / Ramp)	$0	30 min	Better expense tracking + cash flow than personal card
4	**Accounting / bookkeeping system** (QuickBooks Online or Xero)	$30-200/mo	2 hr setup	Required for tax filing, financial reporting, cap table updates
5	**Registered agent service** (if not your home state)	$50-300/yr	30 min	Delaware C-corps need a Delaware registered agent; CSC, Harvard Business Services, Northwest are common
6	**Domain registration** (echoaurion.com etc.)	$15-50/yr per domain	30 min	Cloudflare or Namecheap
7	**Business email** (Google Workspace)	$7/user/mo	30 min	Required for `privacy@echoaurion.com` etc.
8	**GitHub Organization** (if you don't have one)	$0-21/user/mo	30 min	Code lives under the org, not under personal account

#	Item	Cost	Time	Why
9	**Slack workspace**	$0-15/user/mo	30 min	Communications
10	**General liability + tech E&O insurance**	$5,000-15,000/yr	1-2 weeks	Standard SaaS table-stakes; required by enterprise customers
11	**Cyber liability insurance**	$5,000-25,000/yr	1-2 weeks	Required for SOC 2 + most enterprise contracts
12	**D&O insurance** (when board forms)	$3,000-10,000/yr	1-2 weeks	Standard board-formation prerequisite
13	**Trademark watch service** (after filing)	$200-500/yr	30 min setup	Alerts you when someone else files a similar mark
14	**Stock plan** (for option grants)	$1,000-2,500 legal one-time	1-2 weeks	The legal framework that lets you grant options

Insurance brokers that work well with SaaS startups

· **Vouch** — startup-focused; bundles GL + tech E&O + cyber + D&O; pricing is competitive and the UI is modern · **Embroker** — comparable · **Founder Shield** — focuses on tech startups; good for enterprise-customer-required cyber coverage · **AXIS / Travelers** — traditional carriers; typical via a broker

Recommendation: Vouch for the bundle. They quote in 24 hours and the policy is structured for your stage.

Recommended sequence (this month)

1. Confirm EIN (you should already have one from incorporation; if not, https://irs.gov/businesses/small-businesses-self- employed/apply-for-an-employer-identification-number-ein-online)
2. Open business bank account (Mercury) — 30 min
3. Set up business credit card (Brex / Ramp) — 30 min
4. Set up accounting (QuickBooks Online or Xero) — 2 hours
5. Set up Google Workspace — 30 min
6. Set up GitHub Org (move repo if not already) — 30 min
7. Get insurance quote (Vouch) — 1 day to get quote, 1-2 weeks to bind
8. Engage trademark attorney for top 4 marks — 2 weeks
9. Engage corporate attorney for founder CIIA + cap table — 2 weeks

Total cost month 1: ~$5,000-10,000 (mostly attorney + insurance deposits). Total time: ~30-50 hours of your time.

Total program — what this institutional packet costs all-in

Category	Item	Cost (range)
P.1	Founder + Employee + Contractor IP templates	$2,500-4,500
P.7	Privacy Policy + DPIA + Subprocessor list	$1,500-3,000
P.9	Cap table tooling + 409A first pass	$200-300/mo + $1,000-2,500
P.3	Trademark filings (top 4 of 13)	$5,000-8,000
P.4	SOC 2 Type I program (Vanta + auditor)	$22,000-45,000
P.5	First pen-test	$25,000-60,000
P.6	409A valuation (bundled with cap table)	included in $200-300/mo above
Bonus	Insurance + accounting + ops tooling	$10,000-25,000/yr
TOTAL	**All-in for the institutional readiness program**	**$67,000-150,000 first year**

That number sounds large. Three notes: 1. **Most of it is one-time** (P.1, P.3, the first 409A, the first pen-test, the SOC 2 Type I report) 2. **Most of it pays for itself** through customer trust + the ability to land enterprise contracts that wouldn't sign without these artifacts 3. **It can be staged** — you don't have to spend all of it in month one. The this-week list (~$5-10k) does the highest- leverage work first.

The honest truth: pre-seed companies routinely skip this checklist and find themselves blocked at the Series A diligence or the first enterprise contract. The companies that do this work in months 1-3 close their funding rounds 30-60 days faster and at higher valuations because the diligence is clean.

P7 · Privacy Packet

P.7 — Privacy Policy + DPIA + Subprocessor List

> *Customer-facing privacy posture.* ***Draft templates ready for attorney review and publication.*** *Echo / LUCCCA already has the strongest privacy substrate of any platform at this stage (the 8 Privacy Tenets, the doctrine-as-code architecture, the decay engine, the forbidden-path partition). This packet wraps that substrate in the customer-facing language and compliance artifacts that GDPR / CCPA / SOC 2 reviewers expect.*

Why this matters

Three audiences read your privacy posture:

1. **Customers** — read the privacy policy before signing the contract. Sets trust.
2. **Regulators** — GDPR's Article 30 requires a record of processing activities; CCPA requires specific disclosures; a DPIA is required for high-risk processing.
3. **Auditors** — SOC 2 + ISO 27001 both expect a published subprocessor list, a DPIA, and a privacy policy aligned with declared controls.

What's already in the codebase that 99% of pre-seed startups lack: · The 8 Privacy Tenets in `PRIVACY_TENETS.md` (capture by observation; score persists, audio evaporates; tone informs care never commerce; trust score is invisible; guest controls are first-class; staff transparency runs both ways; sensitive flags decay; forbidden uses) · The decay engine (Tenet 7 enforced in code) · The compile-time forbidden-path partition (Tenet 8 enforced statically) · The append-only event log with cryptographic doctrine binding · The trust-score-server-side-only invariant (Tenet 4)

This packet is the customer-facing wrapper. The hard work is done.

Document 1 — Privacy Policy (publishable)

> ***Place at:*** `https://echoaurion.com/privacy` *(or wherever your public site lives) and link from the in-app footer.*

```
# Privacy Policy

**Effective Date:** [DATE]
**Last Updated:** [DATE]

This Privacy Policy explains how Aurion Holdings, Inc. ("Aurion,"
"we," "our," or "us") collects, uses, discloses, and protects
personal information when you use the Echo / LUCCCA platform (the
"Services").

## Our promise (the only sentence that matters)

> *"Aurion learns you to serve you better. It forgets when you ask.
> It never sells you to anyone."*

The eight Privacy Tenets at the bottom of this Policy are the
operational rules that make that sentence literally true. They
are enforced in our code, not just our marketing copy.

## 1. Who we are (the controller)

Aurion Holdings, Inc.
[Registered Address]
[Email: privacy@echoaurion.com]
[Data Protection Officer: TBD]

For European users, our representative under GDPR Article 27 is
[TO BE APPOINTED].

## 2. What we collect

### 2.1 Information that customers (operators) provide directly
  · Account information: name, email, role, organization, phone
  · Property and operational data: outlets, employees, vendors,
    menus, recipes, schedules, financial accounts, GL codes
  · Configuration: budgets, forecasts, notes, overrides

### 2.2 Information generated through use of the platform
  · Operational events: POS check-closes, reservations, capture
    events, audit events, manager notes
  · Service interactions: voice recordings (only if explicit opt-
    in), tone analysis (transient), guest preferences derived
    from observation
  · Performance metrics: forecast accuracy, capture ratios,
    yield-per-occupied-minute

### 2.3 Information from third-party integrations (with your
authorization)
  · POS systems (Toast, Aloha, Micros, Square, Clover)
```

```
  · PMS systems (Opera Cloud, Mews, Cloudbeds)
  · Payroll systems (ADP, Gusto, Paychex)
  · Banking / merchant accounts (Plaid, Stripe)
  · Channel managers (SiteMinder, RateGain)

### 2.4 Information we do NOT collect
  · We do **not** ask guests to fill out preference forms,
    satisfaction surveys, or kiosk ratings. (Privacy Tenet 1.)
  · We do **not** store raw guest audio beyond 24 hours unless
    the guest explicitly opts in. (Privacy Tenet 2.)
  · We do **not** display trust scores to guests. (Privacy Tenet 4.)

## 3. How we use the information

  · **Provide the service** — operate the platform, serve the
    operator's queries, generate the forecasts and dashboards.
  · **Improve forecasts** — the active learning loop nudges per-
    outlet weights based on historical accuracy, never based on
    individual guest behavior in ways that violate Tenet 8.
  · **Operate the brigade** — schedule shifts, run payroll,
    process invoices, close the books.
  · **Audit and compliance** — append-only event logs, doctrine
    enforcement, regulatory reporting.

We do **NOT** use the information for:
  · Pricing decisions or dynamic upsell (Tenet 8)
  · Advertising or third-party data sharing (Tenet 8)
  · Psychological profiling beyond service interaction (Tenet 8)
  · Discrimination on protected characteristics (Tenet 8)
  · Training models for use outside the Echo Resonance network
    (Tenet 8)

## 4. Legal bases (GDPR users)

For users in the European Economic Area, United Kingdom, or
Switzerland, we process personal data on these legal bases:

  · **Contract** — to provide the Services to the operator who
    contracted with us.
  · **Legitimate interests** — to maintain the security and
    integrity of the Services, prevent fraud, and operate the
    business.
  · **Consent** — for any voice recording beyond the 24h decay
    window, for any marketing communications, and for any
    analytics processing not strictly necessary for the Services.
  · **Legal obligation** — to comply with regulatory requirements,
    tax law, audit obligations.

You may withdraw consent at any time without affecting the
lawfulness of prior processing.
```

```
## 5. Sharing of information

We share personal information only with:

  · **Subprocessors** listed at https://echoaurion.com/subprocessors
    (or see Document 3 of this packet). Each is contractually
    bound to data-protection terms equivalent to ours.
  · **Authorized integrations** that the operator opts in to
    (POS, PMS, payroll, banking).
  · **Regulators or law enforcement** under valid legal process.
  · **Acquirer or successor** in the event of a corporate
    transaction (acquisition, merger), with notice to operators
    and the obligation that the successor honor this Policy.

We do **NOT** sell personal information. We do **NOT** share for
third-party marketing. (Tenet 8.)

## 6. International data transfers

We host primarily in [REGION — likely US (AWS/MongoDB Atlas us-
east-1)]. For users in the EEA / UK / Switzerland, transfers to
the United States rely on the EU Standard Contractual Clauses
(SCCs) plus supplementary measures (encryption in transit and
at rest, encryption-key segregation, doctrine §3.1 append-only
event log).

## 7. How long we keep information

  · **Operational data** (transactions, GL entries, audit events)
    — retained for the term of the contract plus 7 years for
    accounting and regulatory purposes.
  · **Voice recordings** — 24 hours unless explicit opt-in.
    (Tenet 2.)
  · **Sensitive psychological flags** (mental health, family
    tension, relationship strain) — auto-decay within 30 days
    unless renewed. (Tenet 7.)
  · **Trust scores** — retained for the duration of the operator's
    relationship; never displayed to the guest. (Tenet 4.)
  · **Aggregated and anonymized data** — may be retained
    indefinitely.

When a guest requests deletion (Tenet 5), we cryptographically
shred the keys protecting their personal data; the event log
remains intact for audit purposes but the personal data within
it is unreadable.

## 8. Your rights

Subject to applicable law (GDPR, CCPA, etc.), you have the right
to:
  · **Access** the personal information we hold about you
```

```
  · **Correct** inaccurate information
  · **Delete** your personal information ("Right to Erasure")
  · **Port** your data to another provider
  · **Object** to certain processing activities
  · **Withdraw consent** at any time
  · **Lodge a complaint** with a supervisory authority

Echo Resonance guests using the platform exercise these rights
through the four operator-provided controls (Tenet 5):
  · "What do you remember about me?"
  · "Pause Aurion"
  · "Delete everything"
  · "See my data"

Property operators (the Aurion customer) exercise these rights
by emailing privacy@echoaurion.com.

We will respond within 30 days (45 days for complex requests).

## 9. Security

  · Encryption at rest (AES-256) and in transit (TLS 1.3+)
  · Append-only event log with cryptographic doctrine binding
  · Compile-time forbidden-path partition preventing prohibited
    code paths from existing in the deployed binary
  · Sensitive-flag decay enforced at the storage layer
  · SOC 2 Type I evidence collection in progress; Type I report
    available [DATE] / Type II report available [DATE]
  · Annual independent penetration testing
  · Multi-factor authentication on all administrative access
  · Audit log of every administrative action (admin_audit_log)

## 10. Children

The Services are not directed to children under 13. We do not
knowingly collect personal information from children under 13.
For the avoidance of doubt, the platform does process minor-
guest data (e.g., a child guest at a hotel) on the operator's
behalf with the lawful basis being the operator's contractual
relationship with the guest's parent / legal guardian.

## 11. Changes to this Policy

We will notify you of material changes via in-app notification
and email at least 30 days before the change takes effect. The
"Last Updated" date at the top reflects the most recent change.

## 12. Contact us

privacy@echoaurion.com
[Mailing address]
```

```
[Phone]

For users in the European Economic Area, our designated
representative is [TBD].

---

## The Eight Privacy Tenets (the constitution)

These rules are enforced in our code. They are not aspirational
marketing language.

### Tenet 1 — Capture by observation, not interrogation
Data is collected through what staff observe and what guests
volunteer in the natural flow of service. The platform never
asks the guest to fill out a preference form, complete a
satisfaction survey at a kiosk, or rate their meal on a screen.

### Tenet 2 — Score persists, audio evaporates
The arousal, valence, and resonance score is retained because
the lift trajectory matters. The raw audio is deleted within 24
hours unless the guest explicitly opts in.

### Tenet 3 — Tone informs care, never commerce
Tone-of-voice analysis affects which staff member responds, what
tempo to use, what intervention is suggested. It never affects
pricing, what is upsold, what advertising is shown.

### Tenet 4 — Trust score is invisible
Every guest has an internal trust score. The score is never
displayed to the guest. It never triggers a confrontation. Its
only effect is on what Echo decides not to do.

### Tenet 5 — Guest controls are first-class
Every guest has, in the app, one-tap access to: "What do you
remember about me?", "Pause Aurion", "Delete everything", "See
my data."

### Tenet 6 — Staff transparency runs both ways
Staff can see what Aurion whispered to them. They can flag a
whisper as "wrong." They can mute Aurion at any time.

### Tenet 7 — Sensitive flags decay aggressively
Mental health flags, family tension flags, relationship strain
flags — the most sensitive signals — auto-decay within 30 days
unless renewed.

### Tenet 8 — Forbidden uses
The platform never uses voice analysis, Resonance scores, or
behavioral signals for: pricing decisions or dynamic upsell;
advertising or third-party data sharing; psychological profiling
```

```
beyond service interaction; discrimination on protected
characteristics; training models that will be used outside the
Echo Resonance network.

---

End of Privacy Policy.
```

Document 2 — Data Protection Impact Assessment (DPIA)

> *Required by GDPR Article 35 for "high-risk" processing. Voice analysis + behavioral inference + cross-property data flows all qualify.* ***Use this template; complete fields before publication / regulator submission.***

A. Description of the processing

Controller: Aurion Holdings, Inc.

Processor: Aurion Holdings, Inc. (we are the controller for operator data and processor for guest data on operators' behalf)

Nature of processing: · Collection of operational data (POS, reservations, service interactions) · Voice analysis (with explicit opt-in for retention beyond 24h; transient analysis without retention is performed for real-time service support) · Inference of guest preferences from observation · Computation of internal trust + resonance scores (server- side only) · Cross-property guest recognition (only for properties under common Echo Resonance network membership)

Scope: · Roughly [N] property operators across [country list] · Estimated [M] guest interactions per month · Estimated [K] employee records

Context: premium hospitality (luxury hotels, restaurants, spas, banquets, casinos) where guests have a reasonable expectation of personalized service.

Purposes: · Operational service delivery · Forecast generation and labor optimization · Audit and regulatory compliance · Guest experience improvement

B. Necessity and proportionality assessment

We have evaluated whether each processing activity is necessary and proportionate:

Processing	Necessity	Less-intrusive alternative considered?	Outcome
Operational data collection	Required to provide the Service	None — operational data is the Service	Necessary
Voice analysis (transient, <24h)	Necessary for real-time service	Could be opt-in only; chose default-on with rapid decay because the lift in service quality is material	Proportionate
Voice retention beyond 24h	NOT default; opt-in only	n/a	Not applicable to default users
Trust score computation	Necessary to prevent guest harm (e.g., refusing to over-serve)	Considered making it opt-out by guest; rejected because the score never affects the guest, only what we decline to do	Necessary, server-side only
Cross-property recognition	Necessary for the Echo Resonance network experience	Could be per-property only; chose network-wide because it's the differentiating value	Proportionate, with opt-out

C. Identification of risks

· **Risk:** voice recording leaks → privacy harm **Mitigation:** 24h decay (Tenet 2), encryption at rest, cryptographic key shredding on delete request (Tenet 5) **Residual risk:** Low

· **Risk:** trust score used for guest-facing actions (discrimination) **Mitigation:** server-side-only invariant enforced at the storage layer (Tenet 4); compile-time forbidden-path partition prevents trust_score from being imported into advertising / pricing modules (Tenet 8) **Residual risk:** Very low

· **Risk:** sensitive psychological flags persist beyond their relevance window **Mitigation:** decay engine (Tenet 7) auto-tombstones flags after 30 days unless explicitly renewed **Residual risk:** Low

· **Risk:** model training on guest data leaks identity **Mitigation:** Tenet 8 prohibits training models for use outside the Echo Resonance network; in-network training uses differentially-private aggregation **Residual risk:** Low

· **Risk:** cross-property recognition surfaces guest at a property they didn't intend to visit **Mitigation:** network membership opt-in by guest; per- property opt-out always available **Residual risk:** Low

· **Risk:** subprocessor breach **Mitigation:** all subprocessors contractually bound; encryption keys segregated where possible; the platform operates on least-privilege access patterns **Residual risk:** Medium (inherent to using cloud infrastructure)

D. Measures envisaged

· Technical: see security section of Privacy Policy + the architecture moat (doctrine-as-code, append-only event log, decay engine, forbidden-path partition) · Organizational: SOC 2 Type I + Type II audits, annual pen-test, founder + employee CIIA agreements with strict confidentiality · Procedural: 30-day SAR response, automated DSAR fulfillment via the Tenet 5 controls, data-protection officer designated

E. Outcome of the assessment

Conclusion: Processing is lawful, necessary, and proportionate under GDPR Article 35. Mitigations are sufficient. No prior consultation with the supervisory authority is required.

DPIA owner: [Data Protection Officer name] **Last reviewed:** [DATE] **Next review:** [DATE + 12 months, or sooner if processing changes materially]

Document 3 — Subprocessor List (publishable)

> ***Place at:*** `https://echoaurion.com/subprocessors`*. Update whenever a subprocessor is added or removed; notify operators 30 days in advance per Article 28(2).*

Current subprocessors as of [DATE]

Subprocessor	Service	Data location	DPA
MongoDB Atlas (MongoDB, Inc.)	Primary database	US (AWS us-east-1)	https://www.mongodb.com/legal/dpa
Anthropic, PBC	LLM API for OCR + variance commentary + Sous-Chef-CFO Q&A	US	https://anthropic.com/legal/dpa (Enterprise)
Amazon Web Services (AWS)	Compute, storage, networking	US (us-east-1)	https://aws.amazon.com/service-terms/ + DPA
Cloudflare	CDN + WAF	Global edge	https://www.cloudflare.com/cloudflare-customer-dpa/
Twilio	SMS notifications (when enabled)	US	https://www.twilio.com/legal/data-protection-addendum
Resend (or SendGrid)	Transactional email	US	[vendor DPA]
Stripe	Payment processing (when wired)	US, EU	https://stripe.com/dpa

Subprocessor	Service	Data location	DPA
Plaid	Banking / merchant data ingestion (when wired)	US	[vendor DPA]
Anthropic Claude (model usage)	LLM inference	US (Anthropic infra)	Enterprise agreement
Sentry / Datadog (when wired)	Observability	US	[vendor DPA]

Subprocessors that will be added during integration (with notice)

· POS systems (Toast / Aloha / Micros / Square / Clover) — only connected when an operator opts in · PMS systems (Opera Cloud / Mews / Cloudbeds) — only connected when an operator opts in · Payroll providers (ADP / Gusto / Paychex / Rippling) — only connected when an operator opts in · Channel managers (SiteMinder / RateGain) — only connected when an operator opts in

Notification policy

We will notify operators of new subprocessors at least 30 days before they begin processing operator data, unless emergency substitution is required for security or continuity reasons (in which case we will notify within 5 business days).

Operators may object to a new subprocessor; if a satisfactory alternative cannot be agreed within 60 days, the operator may terminate the affected service component without penalty.

What you do this week

1. **Have an attorney review the Privacy Policy** — fill in bracketed fields, customize the contact addresses, confirm the data-host region(s) match your actual deployment.
2. **Designate a Data Protection Officer (DPO)** — for now, this can be you. When you have a real privacy / compliance hire, re-designate.
3. **Publish the Privacy Policy at echoaurion.com/privacy** — even before the platform is GA, having it live is the standard trust artifact.
4. **Publish the Subprocessor List at echoaurion.com/subprocessors.**
5. **File the DPIA in your compliance records** — not public, but ready to produce on demand to a regulator or an auditor.
6. **Add a privacy@echoaurion.com email + monitor it.** Even if it's just a forwarder to your personal email for now.
7. **Add a "Privacy" link to the in-app footer** linking to the public Privacy Policy.

Estimated cost + time

Item	Cost	Time
Privacy attorney review of these drafts	$1,500-3,000	1-2 weeks
DPO designation (you, for now)	$0	30 min
Publish Privacy Policy + Subprocessor List	$0	1 hr
Email forwarder + monitoring routine	$0	30 min
Total	**$1,500-3,000**	**2 weeks**

GDPR + CCPA require this; SOC 2 audits expect it; customers ask for it. Cheap, fast, high-leverage.

P9 · Cap Table Guide

P.9 — Cap Table 101 + Starter Template + Tooling

> ***You asked: "cap table might be built but I don't know what it is."*** *This document is the from-scratch explainer.*

What a cap table is, in plain English

A **capitalization table** ("cap table") is a single spreadsheet that answers one question: **"who owns what percentage of the company?"** Every share of stock, every option grant, every warrant, every convertible note — all of it on one document.

It's the artifact that 409A reviewers, investors, acquirers, and auditors look at first because it's the answer to "what are we buying?" or "what are we valuing?"

A clean cap table makes due diligence painless. A messy or missing cap table delays funding by weeks and can kill deals.

For Echo / LUCCCA today, your cap table is probably very simple: **you own 100% of the founder common stock issued at incorporation.** That's the right starting state. The work is to *write it down correctly* so it stays clean as the company grows.

The pieces of a cap table

Term	What it means	Typical numbers
Authorized shares	The total shares the company COULD issue, set in the certificate of incorporation	10,000,000 typical for a Delaware C-corp
Issued shares	Shares actually issued to someone	8,000,000 to founder + 2,000,000 unissued reserved for the option pool
Outstanding shares	Issued shares that haven't been bought back; the basis for ownership %	Usually = issued shares
Common stock	What founders + employees + most option holders get	Lower priority in liquidation

Term	What it means	Typical numbers
Preferred stock	What investors get	Senior in liquidation; protective rights
Option pool	Shares reserved for future employee grants	10-15% pre-seed; 15-20% pre-Series A
Vesting	The schedule by which someone earns their shares over time	Standard: 4 years with 1-year cliff, monthly thereafter
Cliff	The minimum time before any vesting kicks in	Standard: 12 months
Strike price	What an option-holder pays to exercise an option	Typically the 409A FMV at grant date
FMV (fair market value)	What the common stock is worth per share for tax purposes	Set by the 409A valuation
Fully diluted shares	All issued + all reserved + all options + all warrants + all convertibles, as if everyone exercised	The denominator for "diluted ownership %"

Your starter cap table (from where you are today)

Assuming you incorporated as Aurion Holdings, Inc. with the standard Delaware C-corp setup:

```
AURION HOLDINGS, INC. — CAPITALIZATION TABLE
As of: [DATE OF INCORPORATION]

AUTHORIZED SHARES
  Common Stock:                      10,000,000
  Preferred Stock:                            0  (none authorized yet)
  Total Authorized:                  10,000,000

ISSUED + OUTSTANDING SHARES (at $0.0001 par value)

Holder                   Shares      % Outstanding   % Fully-Diluted   Vesting
────────────────────────────────────────────────────────────────────────────────────────────────────────────────
──────────────────────────────────────────────
William Morrison       8,000,000        100.0%           80.0%        4yr/1yr cliff
                                                                       starting [DATE]

OPTION POOL (reserved, not issued)
Reserved for future
  employee grants     2,000,000          n/a             20.0%        per grant

TOTAL FULLY DILUTED  10,000,000                          100.0%
```

That's the starter state. The percentages move when: · You issue stock to a co-founder (rare — you've said you're solo) · You issue option grants to first hires (chips out of the option pool) · You raise a seed round (issues new preferred shares; dilutes everyone proportionally)

The math when you raise a seed round

Suppose you raise $1.5M at a $7.5M post-money valuation on a SAFE or a priced round. Roughly:

· Investors get 20% of the post-money company · You + the option pool dilute from 100% to ~80% of the post-money fully diluted total · Your founder shares (8M) stay 8M, but the denominator goes from 10M to ~12.5M, so your % drops

A cap table tool calculates this automatically. Doing it by hand is error-prone and painful.

Founder vesting — the part most solo founders skip and regret

Even though you're solo, **you should put your founder shares on a 4-year vesting schedule with a 1-year cliff.** Investors will require this when you raise. Doing it now is cheap; doing it later means giving up shares you thought you owned.

The mechanism: instead of holding 8,000,000 shares outright, you hold them subject to a vesting schedule: · 0% vested at issuance · 25% vest at the 1-year anniversary (the "cliff") · 1/48 vest each month thereafter · 100% vested at the 4-year anniversary

If you leave (or get fired by a future board) before fully vested, the company can repurchase the unvested shares at par value.

Why this matters: if you DON'T have founder vesting and you later hire a co-founder who quits at month 13, they walk with 50% of the company. With vesting, they walk with 12.5% (the vested portion) and the company gets the rest back to redistribute.

Standard founder vesting also includes: · **Single-trigger acceleration** on involuntary termination (you get bought out, fired without cause) · **Double-trigger acceleration** on change-of-control AND involuntary termination within 12-24 months of close

Your attorney sets this up via a Restricted Stock Purchase Agreement (RSPA). Cost: included in the $1,500-2,500 founder package. Time: ~2 weeks.

Important: file an 83(b) election within 30 days of buying the stock. This locks in the tax treatment so you don't owe income tax on the spread between strike and fair value at each vesting date. Skipping this is the single most expensive mistake a founder can make. Your attorney will remind you; do not miss it.

The 409A valuation — what it is and why you need it

A **409A valuation** is an independent appraisal of your common stock's fair market value (FMV). It's required because:

· IRS Section 409A penalizes employees if you grant options at a strike price *below* FMV. The penalty is 20% additional tax on top of regular income tax, plus interest. · So you need a defensible FMV to set option strike prices. · The valuation must be done by an "independent" appraiser (you can't do it yourself).

A 409A is required when: · You're about to grant your first stock options (to first hire) · You're about to raise a priced round (preferred stock changes the common's value) · You haven't had one in the last 12 months

For a pre-seed company with no revenue and no funding, a 409A typically values the common stock at **$0.001 to $0.05 per share.** Once you raise seed, it jumps to $0.10-0.50/share. Once Series A, $0.50-2.00.

Cost + timing

· **DIY tools (Carta, Pulley, etc.):** included in the $200- 600/month subscription. Turnaround: 5-15 business days. · **Independent firms (Aranca, Scalar, Andersen, Murphy McCann):** $5,000-15,000 standalone. Turnaround: 3-4 weeks.

For your stage, use Carta or Pulley's built-in 409A. The bundled tools have made this cheap. Don't pay BigLaw rates here.

Cap table tooling — the comparison

Tool	Best for	Pricing (approx)	409A included?
Carta	Most common; everyone in venture knows it	$200-1,500/mo depending on number of stakeholders + features	Yes (Carta 409A)
Pulley	Cheaper, modern, founder-friendly	$200-800/mo	Yes
AngelList Stack	Free option tier; good for early stage	Free → paid tiers	Through partner
Eqvista	Cheap option	$150-500/mo	Yes
Excel / Google Sheets	Fine for the literal first 6 months	Free	Not by itself

Recommendation for your stage: Pulley or **Carta Launch (free tier).** · Pulley's pre-seed pricing is the lowest and the UX is the cleanest. · Carta's brand recognition is the strongest with investors. · Either is fine. **Don't keep your cap table in a spreadsheet once you have more than 2 stakeholders.**

Your starter cap table CSV (drop this into Pulley or Carta)

Save the following as `cap_table_starter.csv` and import it into your chosen tool. The tool will normalize and audit-trail it.

```
holder_name,holder_email,security_type,share_class,shares,issue_date,vesting_start_date,vesting_term_months,
cliff_months,certificate_number
William Morrison,[your email],founder_common,Common,8000000,[INCORPORATION_DATE],[VESTING_START_DATE],
48,12,CS-1
[Future Pool],,option_pool_reserved,Common,2000000,[INCORPORATION_DATE],,,,
```

Replace the bracketed fields. The vesting_start_date is typically the same as the incorporation date, but you can set it to your "first day of working on the company" if that was earlier and your attorney advises (some founders backdate vesting to capture pre- incorporation work; this needs care).

What you do this week

1. **Find your incorporation paperwork.** You should have: · Certificate of Incorporation (Delaware, filed by your attorney or via Stripe Atlas / Clerky / OpenForms) · Bylaws · Stock purchase agreement (the founder common shares) · 83(b) election filing receipt (if filed) · EIN (employer identification number from the IRS)

If you don't have these, that's the first homework. Use **Stripe Atlas ($500), Clerky ($349-799), or a Delaware C- corp attorney ($1,500-3,000).** All of them produce the same output paperwork.

1. **Verify your 83(b) election was filed within 30 days of stock issuance.** If you missed it, talk to a tax attorney immediately — there are sometimes ways to mitigate.
2. **Confirm your founder vesting schedule.** If you didn't put your founder shares on a vesting schedule, retroactively doing it requires consideration to be paid; an attorney can structure this. Cost: $500-1,500.
3. **Pick a cap table tool.** Pulley, Carta, or AngelList Stack. Sign up; import the starter CSV.
4. **Get your 409A valuation done.** Through Pulley or Carta is simplest at this stage. Cost: bundled with the subscription at the entry tier.
5. **File the cap table in the company records folder** alongside your incorporation docs.

Estimated cost + time

Item	Cost	Time
Verify incorporation paperwork is in order	$0 (or $500 to redo via Stripe Atlas)	1 hour
Founder vesting set up via RSPA + 83(b)	$500-1,500	1-2 weeks
Cap table tool (Pulley or Carta)	$0-300/mo	30 min to set up
409A valuation (bundled with tool)	$0 (free tier) - $1,500	5-15 business days
Total	**$500-3,000 + $0-300/mo**	**~3 weeks**

Cap table cleanup is one of the cheapest items on the institutional checklist. The cost is mostly one-time legal time to structure the founder vesting; after that, the tool maintains itself for ~$200/mo.

What "first thing a 409A reviewer reads" looks like in practice

When a 409A appraiser, an investor, or an acquirer gets your cap table, they check:

1. **Total fully diluted shares** — does it tie to the authorized share count + the option pool? (Catch: companies that grant options exceeding the authorized pool.)
2. **Founder shares vested vs unvested** — is the founder committed (vested portion small relative to total)?
3. **Option grants** — strike price = 409A FMV at grant date? Vesting schedule conventional (4yr/1yr cliff)?
4. **Convertible notes / SAFEs** — terms reasonable? Maximum valuation cap? Discount rate?
5. **Preferred stock terms** — liquidation preference 1x non- participating (founder-friendly) vs 2x participating (investor-friendly)?
6. **Anti-dilution** — broad-based weighted-average (founder- friendly) vs full ratchet (rare and harsh)?
7. **Drag-along rights** — present and balanced?
8. **Information rights** — present and reasonable?

For a clean pre-seed cap table (just founder shares + option pool reserve), most of these are blank. **Blank is good at this stage.** It means you haven't taken bad terms from someone yet.

Honest closing

You're solo. Your cap table is going to be the simplest one a reviewer ever sees: 100% founder common, with a 20% option pool reserved. **Get it written down correctly in a real tool, get your founder vesting on paper, and get the 409A done.** That's the entire P.9 lift, and it costs ~$500-3,000 plus ~$200/mo tooling for the rest of the company's life.

Once it's clean, every subsequent grant, every fundraise, every diligence pass, just adds rows to the table. The tool maintains the integrity. Your job is to keep the inputs clean.

T1-A5 · Terms of Service

Terms of Service — Aurion Holdings, Inc.

> ***DRAFT TEMPLATE — review with attorney before publishing.*** *Place at* `https://echoaurion.com/terms` *once finalized.*

TERMS OF SERVICE

Effective Date: [DATE] **Last Updated:** [DATE]

These Terms of Service ("Terms") govern your access to and use of the Echo / LUCCCA platform (the "Services") provided by Aurion Holdings, Inc., a Delaware corporation ("Aurion," "we," "our," or "us"). By accessing or using the Services, you ("Customer," "you," or "your") agree to be bound by these Terms.

1. Definitions

· **"Customer"** — the legal entity or individual that contracts with Aurion for use of the Services · **"Authorized Users"** — Customer's employees, contractors, and agents authorized by Customer to access the Services · **"Customer Data"** — all data submitted by Customer or generated by Authorized Users through the Services, including operational data, financial records, and configuration · **"Documentation"** — the user guides, API documentation, and runbooks made available by Aurion · **"Order Form"** — the document signed by Customer specifying pricing, term, and configuration · **"Subprocessors"** — third parties listed at https://echoaurion.com/subprocessors that process Customer Data on our behalf

2. License Grant

Subject to these Terms and Customer's payment of fees, Aurion grants Customer a non-exclusive, non-transferable, non-sublicensable right to access and use the Services during the Term solely for Customer's internal business operations.

3. Restrictions

Customer shall not: · Reverse engineer, decompile, or disassemble the Services · Resell, sublicense, or commercially exploit the Services · Use the Services to develop a competing product · Use the Services in violation of applicable law · Attempt to bypass authentication or access controls · Send malware, conduct denial-of-service attacks, or otherwise interfere with the Services · Exceed reasonable usage thresholds defined in the Order Form without Aurion's consent · Upload Customer Data containing illegal content

---

4. Customer Data and Ownership

· Customer retains all right, title, and interest in Customer Data · Customer grants Aurion a worldwide, non-exclusive, royalty-free license to use, host, store, transmit, display, and process Customer Data solely as needed to provide the Services · Aurion will use Customer Data in accordance with our Privacy Policy (https://echoaurion.com/privacy) and will not sell Customer Data to any third party · Aurion will not use Customer Data to train models for use outside the Echo Resonance network (per Privacy Tenet 8)

---

5. Aurion's Intellectual Property

· Aurion retains all right, title, and interest in the Services, including the platform code, the doctrine framework, the forecasting models, the Echo brand marks, and any improvements or derivative works · No license to Aurion's intellectual property is granted except as expressly set forth in Section 2

---

6. Confidentiality

Each party agrees to (a) hold the other's Confidential Information in strict confidence, (b) use it solely as needed to perform under these Terms, and (c) protect it with the same care as its own confidential information (and in no event less than reasonable care). Confidential Information does not include information that is publicly available, independently developed, or rightfully received from a third party without restriction.

---

7. Service Levels and Support

· The Service Level Agreement (SLA) is incorporated by reference and posted at https://echoaurion.com/sla · Standard support: 24/5 during onboarding, 24/7 by Year 2 of Customer's relationship · Service availability is monitored at https://status.echoaurion.com

---

8. Fees and Payment

· Fees are specified in the Order Form · Fees are due 30 days from invoice date unless otherwise specified · Late payments accrue interest at the lesser of 1.5%/month or the maximum permitted by law · All fees are non-refundable except as specified in the SLA (service credits) or as required by applicable law · Annual fees are subject to a CPI + 3% escalator at renewal, capped at 7%

---

9. Term and Termination

· The Term is specified in the Order Form (typically 24 months initial, with auto-renewal for 12-month periods) · Either party may terminate for material breach with 30 days' written notice and opportunity to cure · Customer may terminate for convenience at month 13 of the initial term with 60 days' written notice and pro-rata refund of prepaid fees · Aurion may suspend or terminate for non-payment, breach of Restrictions, or applicable law · Upon termination, Customer's data is exported in standard format within 30 days; thereafter retained for 90 days then cryptographically deleted (per Privacy Tenet 5)

---

10. Warranties and Disclaimers

· Aurion warrants that the Services will substantially conform to the Documentation when used as intended · Aurion warrants that the Services do not infringe third-party intellectual property rights · EXCEPT AS EXPRESSLY SET FORTH ABOVE, THE SERVICES ARE PROVIDED "AS IS" WITHOUT WARRANTIES OF ANY KIND, INCLUDING WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE

---

11. Indemnification

· Aurion will defend Customer against any third-party claim that the Services, as provided, infringe a U.S. intellectual property right, and will pay damages awarded against Customer by a court of competent jurisdiction · Customer will defend Aurion against any third-party claim arising from (a) Customer Data, (b) Customer's misuse of the Services, or (c) Customer's violation of law · The indemnifying party's obligations are subject to (a) prompt notice, (b) sole control of the defense, and (c) reasonable cooperation from the indemnified party

---

12. Limitation of Liability

EXCEPT FOR (A) PARTIES' INDEMNIFICATION OBLIGATIONS, (B) BREACHES OF CONFIDENTIALITY, (C) GROSS NEGLIGENCE OR WILLFUL MISCONDUCT, AND (D) PAYMENT OBLIGATIONS:

· NEITHER PARTY WILL BE LIABLE FOR INDIRECT, CONSEQUENTIAL, SPECIAL, OR PUNITIVE DAMAGES · EACH PARTY'S AGGREGATE LIABILITY UNDER THESE TERMS WILL NOT EXCEED THE FEES PAID OR PAYABLE BY CUSTOMER IN THE 12 MONTHS PRECEDING THE CLAIM

13. Compliance, Privacy, and Security

· Aurion will maintain administrative, physical, and technical safeguards consistent with industry standards (SOC 2 Type I or II, depending on the date of contracting) · Aurion will comply with applicable data protection laws including GDPR and CCPA when processing Customer Data · Aurion will notify Customer of any confirmed Personal Data breach within 72 hours of discovery (or as required by law, whichever is shorter) · Customer is responsible for the security of its Authorized Users' credentials

14. Subprocessors

Aurion engages the Subprocessors listed at https://echoaurion.com/subprocessors. Aurion will notify Customer of new Subprocessors at least 30 days in advance. Customer may object to a new Subprocessor; if a satisfactory alternative cannot be agreed within 60 days, Customer may terminate the affected service component without penalty.

15. Force Majeure

Neither party is liable for delays or failures to perform caused by events beyond reasonable control, including natural disasters, acts of war, terrorism, pandemics, or government action. The affected party will use reasonable efforts to mitigate the impact.

16. Governing Law and Disputes

These Terms are governed by the laws of the State of Delaware, without regard to conflict-of-laws principles. Any dispute will be resolved in the state or federal courts located in Wilmington, Delaware. Each party waives any objection to venue or jurisdiction.

17. General

· **Entire Agreement.** These Terms, together with the Order Form and the SLA, are the entire agreement of the parties. · **Modifications.** Aurion may modify these Terms with 30 days' notice. Material adverse changes give Customer the right to terminate for convenience without penalty. · **Assignment.** Customer may not assign these Terms without Aurion's consent. Aurion may assign in connection with a merger, acquisition, or sale of substantially all assets. · **No Waiver.** Failure to enforce any provision is not a waiver. · **Severability.** If any provision is unenforceable, the remainder of these Terms remains in effect. · **Counterparts; E-signatures.** These Terms may be executed in counterparts, including by electronic signature.

---

18. Contact

· **Legal Notices:** legal@echoaurion.com · **Privacy:** privacy@echoaurion.com · **Security:** security@echoaurion.com

Aurion Holdings, Inc. [Mailing Address]

End of Terms of Service.

T1-A5 · Service-Level Agreement

Service Level Agreement (SLA)

> ***DRAFT TEMPLATE — review with attorney before publishing.*** *Place at* `https://echoaurion.com/sla`*. Incorporated by reference into the Terms of Service.*

SERVICE LEVEL AGREEMENT

Effective Date: [DATE]

This SLA defines Aurion Holdings, Inc.'s commitments regarding the availability and performance of the Echo / LUCCCA Services. This SLA is incorporated by reference into the Terms of Service.

---

1. Availability Commitment

Aurion commits to **99.9% Monthly Uptime** for the production Services, calculated as follows:

```
Uptime % = (Total Minutes - Excluded Minutes - Downtime Minutes)
           ÷ (Total Minutes - Excluded Minutes)
           × 100
```

· **"Total Minutes"** — the total minutes in the calendar month · **"Excluded Minutes"** — see Section 4 (excluded events) · **"Downtime Minutes"** — minutes during which any Tier 1 service tier (see Section 2) is unavailable to Customer

99.9% uptime equals approximately **43.2 minutes** of downtime per month.

---

2. Service Tier Definitions

Per `services/slo.py` in the platform, endpoints are tiered:

· **Tier 1 — Critical** (money, audit, login, health): 99.9% availability, p95 < 500ms, p99 < 2000ms · **Tier 2 — Standard** (dashboards, lists): 99.5% availability, p95 < 1000ms, p99 < 4000ms · **Tier 3 — Analytic** (cross-property, retrospective, heavy aggregation): 99.0% availability, p95 < 5000ms, p99 < 15000ms

Availability commitments above apply to Tier 1. Tier 2 and Tier 3 have their own commitments stated above.

3. Service Credits

If Aurion fails to meet the Tier 1 99.9% Monthly Uptime commitment, Customer is entitled to Service Credits as follows:

Monthly Uptime	Service Credit
≥ 99.9%	0%
99.0% – 99.89%	10% of monthly fee
95.0% – 98.99%	25% of monthly fee
< 95.0%	50% of monthly fee

Service Credits are credited against Customer's next invoice. If the agreement is terminated before that invoice issues, Aurion will refund the credited amount.

Customer must request Service Credits within 30 days of the month-end by emailing `support@echoaurion.com` with the request and downtime evidence.

Service Credits are Customer's **sole and exclusive remedy** for SLA breaches under this Agreement.

4. Excluded Events

The following are excluded from Downtime calculations:

· **Scheduled maintenance** announced ≥ 7 days in advance via email + status page (typically <2 hours/month, off-peak) · **Emergency maintenance** required to fix a critical security vulnerability or active attack · **Force majeure** events (natural disasters, war, terrorism, pandemic, government action) · **Customer-caused issues** (misuse of the Services, customer network connectivity problems, customer credential issues) · **Third-party issues** outside Aurion's reasonable control (Customer's POS / PMS / payroll vendor downtime that prevents integration; ISP outages; DNS provider outages) · **Beta or preview features** explicitly marked as such

5. Status Page

Aurion maintains a public status page at **https://status.echoaurion.com** showing: · Real-time operational status of every Service tier · Open incidents with regular updates · Historical uptime data per tier per month · Scheduled maintenance windows

6. Support Levels

Tier	Available	Response time	Channels
Critical (P1 — production down)	24/7	1 hour	Phone + email + status page
High (P2 — degraded service)	24/5 (24/7 by Year 2)	4 hours	Email + status page
Normal (P3 — non-blocking issue)	Business hours	24 hours	Email + ticketing
Low (P4 — feature request, question)	Business hours	72 hours	Email + ticketing

---

7. Incident Communication

For Tier-1 (Critical) incidents:

· Initial public acknowledgment on the status page within 15 minutes of confirmed incident · Investigation update every 30 minutes until resolution · Post-incident review (PIR) published within 5 business days after resolution, available at the status page archive · Major-incident PIRs (>2 hours of Tier 1 downtime) emailed directly to Customer

---

8. Data Backup and Recovery

· **Backup frequency:** continuous WAL backup + nightly full snapshot · **Backup retention:** 35 days for nightly snapshots, 7 days for point-in-time recovery · **Recovery Point Objective (RPO):** ≤ 1 hour (data loss in a worst-case recovery) · **Recovery Time Objective (RTO):** ≤ 4 hours for the production cluster · **DR drill cadence:** quarterly, with results published to the status page incident archive

---

9. Performance Commitments

In addition to availability, Aurion commits to the following performance targets, measured at the API edge:

Tier	p95 latency target	p99 latency target
Tier 1	500 ms	2,000 ms
Tier 2	1,000 ms	4,000 ms
Tier 3	5,000 ms	15,000 ms

Performance is monitored continuously per `services/slo.py` and made visible in the platform's `/api/slo/dashboard` endpoint.

---

10. Limitations

This SLA does not apply to:

· Beta, preview, or pre-release features · Customer's sandbox or demo environments · One-off custom integrations or professional services · Free or trial accounts

---

11. Modification

Aurion may modify this SLA with 30 days' written notice. Material adverse changes give Customer the right to terminate the underlying agreement for convenience without penalty.

---

12. Contact

· **Status updates:** https://status.echoaurion.com · **SLA inquiries:** support@echoaurion.com · **Service Credit requests:** billing@echoaurion.com

---

End of Service Level Agreement.

T1-4 / T1-6 · Accessibility & Cookies

Accessibility Statement + Cookie Policy

> *Two short customer-facing documents bundled together. Both publishable; both reference legal review.*

T1.6 — Accessibility Statement

> ***Place at:*** `https://echoaurion.com/accessibility`

ACCESSIBILITY STATEMENT

Last Updated: [DATE]

Aurion Holdings, Inc. ("Aurion") is committed to ensuring digital accessibility for people with disabilities. We are continually improving the user experience for everyone and applying the relevant accessibility standards to the Echo / LUCCCA platform.

Our Commitment

We strive to comply with **Web Content Accessibility Guidelines (WCAG) 2.1 Level AA** for the Echo / LUCCCA platform, including:

· Perceivable — all non-text content has text alternatives; color is not the only means of conveying information; sufficient color contrast is maintained · Operable — all functionality is available from a keyboard; users have enough time to read and use content; nothing is designed in a way that triggers seizures · Understandable — text is readable; the platform's behavior is predictable; users are helped to avoid and correct mistakes · Robust — content is compatible with current and future assistive technologies including screen readers

---

Conformance Status

The Echo / LUCCCA platform is **partially conformant** with WCAG 2.1 Level AA. "Partially conformant" means that some parts of the content do not yet fully conform to the accessibility standard. Below is our current honest assessment.

Conformant areas (WCAG 2.1 AA)

· Privacy Policy, Terms of Service, and other public legal pages · Status page (status.echoaurion.com) · Main login flow · Help / documentation site

Areas with known gaps

· Some interactive dashboards (e.g., the Monte Carlo P10/P50/P90 fan chart, the cross-property heatmap) are visually-dense and do not yet have full screen-reader optimizations · Some legacy UI components inherited from earlier prototypes do not yet meet color-contrast targets · The 3D coverage surface visualization on the 21-day forecast does not have a tabular alternative yet (planned: Q3 2026)

Remediation plan

· Q2 2026: Full third-party accessibility audit (Deque or Level Access) · Q3 2026: VPAT (Voluntary Product Accessibility Template) published · Q4 2026: Address all critical + serious findings from the audit · Continuous: every new feature reviewed against WCAG 2.1 AA before release

---

Assistive Technologies Tested

The following assistive technologies are tested against the platform regularly:

· **NVDA** (NonVisual Desktop Access) on Windows · **JAWS** (Job Access With Speech) on Windows · **VoiceOver** on macOS and iOS · **TalkBack** on Android · **Dragon NaturallySpeaking** for voice navigation · **Switch Access** (iOS / Android)

Browsers and Devices

Echo / LUCCCA is tested on: · Chrome 100+, Firefox 100+, Safari 15+, Edge 100+ · iOS 15+ (Safari), Android 11+ (Chrome) · Screen sizes from 360px (small mobile) to 4K desktop

---

Feedback

We welcome your feedback on the accessibility of the Echo / LUCCCA platform. If you encounter accessibility barriers, please contact us:

· **Email:** accessibility@echoaurion.com · **Phone:** [phone] · **Mailing address:** [address]

We try to respond to feedback within **5 business days**.

Procurement Inquiries

For procurement teams requesting accessibility documentation:

· **VPAT (Voluntary Product Accessibility Template):** in progress; expected Q3 2026. Email accessibility@echoaurion.com to be notified when published or to request our current state-of-conformance summary. · **Section 508 Conformance:** we target full alignment with Section 508 standards in parallel with WCAG 2.1 AA.

Date and Method of Statement Preparation

This statement was prepared on [DATE] using: · Self-evaluation against WCAG 2.1 AA criteria · Manual testing with the assistive technologies listed above · Automated scanning via [tool, e.g., axe DevTools, WAVE]

The next planned review is [DATE + 6 months] or earlier if there is a material change to the platform.

End of Accessibility Statement.

T1.4 — Cookie Policy

> ***Place at:*** `https://echoaurion.com/cookies`*. Linked from the Privacy Policy footer and from the consent banner.*

COOKIE POLICY

Effective Date: [DATE] **Last Updated:** [DATE]

This Cookie Policy explains how Aurion Holdings, Inc. uses cookies and similar technologies on the Echo / LUCCCA platform's public website (echoaurion.com), the operator portal (app.echoaurion.com), the documentation site (docs.echoaurion.com), and the status page (status.echoaurion.com).

By using these properties, you consent to the use of cookies as described in this Policy.

What is a cookie

A cookie is a small text file placed on your device when you visit a website. Cookies are widely used to make websites work, more efficient, and to provide information to website operators. Some cookies are essential to the functioning of the site; others require your consent.

We also use **similar technologies** including local storage, session storage, and browser-based fingerprints. References to "cookies" in this Policy include these technologies.

Types of cookies we use

1. Strictly necessary cookies — always enabled

These cookies are essential to operate the platform. You cannot opt out of these because the platform cannot function without them.

Cookie	Purpose	Duration
`session_id`	Maintains your authenticated session	Session
`csrf_token`	Prevents cross-site request forgery attacks	Session
`cookie_consent`	Records your cookie consent choice	12 months

2. Functional cookies — enabled by default; opt-out available

These cookies enable enhanced functionality (e.g., remembering your preferences). They do not track you across other sites.

Cookie	Purpose	Duration
`theme_preference`	Remembers your light/dark theme choice	12 months
`last_property_id`	Remembers the last property you viewed	30 days
`dashboard_layout`	Saves your dashboard layout preferences	12 months

3. Analytics cookies — opt-in only (consent required)

These cookies help us understand how the platform is used so we can improve it. They do NOT identify you personally.

Cookie	Provider	Purpose	Duration
`_ga`, `_ga_*`	Google Analytics 4	Measures visit patterns at the page level	14 months
`posthog_*`	PostHog	Product analytics — feature engagement, funnel completion	12 months

We do NOT use these for advertising, profiling, or selling data.

4. Marketing cookies — opt-in only (consent required)

We do NOT currently use marketing cookies. Per Privacy Tenet 8, we do not engage in third-party advertising or behavioral marketing. If this ever changes, this Policy will be updated and your consent will be re-prompted.

Your choices

When you first visit a public Aurion property, a **cookie consent banner** appears letting you:

· Accept all (necessary + functional + analytics) · Accept only necessary · Customize per category

You can change your preferences at any time by clicking **"Cookie Preferences"** in the footer of any Aurion site, or by clearing your `cookie_consent` cookie and refreshing.

If you opt out of analytics cookies, the platform continues to function fully. You will not see less content; we will simply have less data about how to improve it.

Browser-level cookie controls

Most browsers allow you to: · Block all cookies · Block third-party cookies only · Delete cookies on browser close

Browser instructions: · **Chrome:** Settings → Privacy and Security → Cookies · **Firefox:** Settings → Privacy & Security → Cookies and Site Data · **Safari:** Preferences → Privacy → Manage Website Data · **Edge:** Settings → Cookies and Site Permissions

If you block all cookies, you cannot use authenticated parts of the platform (the operator portal requires session cookies).

Do Not Track signals

We honor "Do Not Track" (DNT) browser signals. When DNT is enabled, we do not load analytics or marketing cookies regardless of consent banner state.

Global Privacy Control (GPC) signals

We honor GPC signals as the equivalent of opting out of analytics + marketing cookies, per the California Consumer Privacy Act (CCPA) Article 1798.135.

Updates to this Policy

We will notify you of material changes via the cookie consent banner (which will re-prompt your consent) and via update of the "Last Updated" date above.

Contact

· **Cookie inquiries:** privacy@echoaurion.com · **Privacy Policy:** https://echoaurion.com/privacy

End of Cookie Policy.

Index · Quick Links

All chapters, alphabetical-by-print-order. Identical to the front-of-doc Quick Links — restated here so the printed copy doesn't have to be flipped to find them.

— END OF DOCUMENT —